// NIST SP 800-171 / CMMC COMPLIANCE CONSULTANTS

CMMC compliance for defense subcontractors, guided by a Cyber AB RPO

We help defense contractors and suppliers get ready for CMMC and NIST SP 800-171, from the first site visit to the annual affirmation.

Book a Discovery Call → 30 min · No sales pitch · Signed NDA

CMMC →
Maturity levels & framework

NIST SP 800-171 →
110 controls & DFARS 7012

CUI →
Controlled Unclassified Info

CMMC READINESS CHECK · 3 MINUTES FREE TOOL

Find out where you stand

Assess your FCI/CUI boundaries and readiness score before a C3PAO audit.

Enter corporate work email

Start 3-Minute Readiness Check →

🔒 Work email required. Never submit classified or CUI information.

ORGANIZATIONS THAT HAVE WORKED WITH SECURE-CENTRIC

tems ⚠ Goodwin & Associates ⚠ HRD Aero Systems ⚠ Precision Aerospace ⚠ Defense Dynamics ⚠ Tower Semiconductor ⚠ Safran Fe

// THE CMMC PROCESS

Your CMMC journey, step by step

View Detailed 8-Step Process →

01	02	03	04	05	06	07	08
Site visit	Scoping	Gap assessment	Remediation	Documentation	Readiness review	Assessment	Maintain

● MILESTONE 01 OF 08 · PHASE 1: FACILITY WALKTHROUGH & SCOPE DISCOVERY 0% Complete ← Prev Milestone Next Milestone →

MILESTONE 01 · SITE VISIT

Site visit

In-person physical & technical walkthrough of facilities, server rooms, and shop-floor enclaves.

Advance to Milestone 02: Scoping → Explore Milestone Scope

WHO DOES THIS WORK
You + Secure-Centric

PRIMARY DELIVERABLE YOU KEEP
Asset discovery baseline & boundary notes

// CLIENT TESTIMONIALS

What Defense Contractors Say About Working With Us

5 Defense Client Reviews • Moving Left → Right • Hover or Tap to Pause

at our facility within two
nd us generic
s—they helped
ewalls, SIEM, and
P.

nalyst, Safran Federal

03

Most consultants sell managed IT products. Secure-Centric provided strictly independent advisory. They worked directly with our internal team and existing MSP without conflicts.

ROL **Rafael Omar Lemus**
IT Director, Goodwin & Associates

04

I would like to thank Secure-Centric and Desmond Thompson, who guided us through the preparation stages for the certification, even before the external assessment.

RA **Regina Amosi**
CISO, Tower Semiconductor
Shared publicly on LinkedIn

05

From scoping out shop-floor test equipment to submitting our SPRS score defense, Secure-Centric made what felt like an impossible 110-control standard manageable.

AL **Albert Leon**
CIO, HRD Aero Systems
Shared publicly on LinkedIn

// SECTION EXPLAINER

What is CMMC compliance?

CMMC (Cybersecurity Maturity Model Certification) is the Department of War standard ensuring defense subcontractors safeguard Federal Contract Information (FCI) and Controlled Unclassified Information (CUI).

Under 32 CFR Part 170 and DFARS 252.204-7021, all contractors handling CUI must achieve Level 2 compliance against the 110 requirements of NIST SP 800-171 Rev 2 before contract award.

Our Cyber AB Registered Practitioners conduct on-site facility walkthroughs, map exact CUI boundaries, guide technical remediation, and co-author your assessor-ready System Security Plan (SSP).

// PROOF & CREDENTIALS

Why Secure-Centric

Secure-Centric is an accredited Cyber AB Registered Provider Organization (RPO). We help defense subcontractors navigate DFARS 252.204-7012, NIST SP 800-171, and CMMC Level 2 audits with defensible, assessor-tested evidence.

Full Company Credentials →

120+
Defense contractors prepared for CMMC & NIST SP 800-171 audits
As of Q4 2026

100%
First-time pass record with Authorized C3PAO and DIBCAC assessors
Level 2 CMMC audits

30 Min
Discovery call delivery: immediate scoping & roadmap guidance
Signed bilateral NDA

Cyber AB Authorized RPO

Formally credentialed by the Cyber AB (RPO #3942) with certified Registered Practitioners (RPs) leading every client engagement on site.

Exclusive CMMC & NIST Focus

We do not sell generic IT services or managed antivirus. Our sole specialization is defense cybersecurity compliance and C3PAO audit readiness.

On-Site Physical & Technical Walkthrough

We walk your facilities, shop floors, and secure server rooms to physically map CUI flows and isolate enclave boundaries.

Independent & Scope-Shrinking Advisory

We provide vendor-neutral advisory to shrink your assessment scope, saving tens of thousands in hardware, software, and audit fees.

OFFICIAL BADGES: Cyber AB RPO #3942 ⭐ Inc. 5000 #452 Fastest Growing 🔒 Bilateral NDA Standard

Los Angeles, California · Nationwide On-Site Deployments

CMMC guides, checklists and tools

CMMC Complete Guide

The definitive executive and technical overview of CMMC levels, rulemaking, and audits.

Explore Resource →

CMMC Level 2 Guide

110 requirements across 14 security families: technical breakdown and scoping rules.

Explore Resource →

NIST SP 800-171 Standard

The foundational standard behind DFARS 7012 and Level 2 C3PAO certifications.

Explore Resource →

CUI Scoping & Handling Guide

Controlled Unclassified Information: identification, markings, and boundary isolation.

Explore Resource →

CMMC Enclave Advisory

How segregating your CUI network saves months of implementation and audit costs.

Explore Resource →

Level 2 Compliance Checklist

Downloadable 110-control Excel checklist with ownership and objective columns.

Explore Resource →

// FREQUENTLY ASKED QUESTIONS

Common questions

Still have questions regarding your specific CMMC clauses or audit dates? Speak directly with our lead Registered Practitioner.

Book a Discovery Call →

What is CMMC compliance? ×

CMMC (Cybersecurity Maturity Model Certification) is the Department of War standard ensuring defense contractors safeguard Federal Contract Information (FCI) and Controlled Unclassified Information (CUI).

Do you come to our site? +

Do you only work on CMMC and NIST SP 800-171? +

What happens after I book a discovery call? +

Who will we work with day to day? +

Planning to get started on CMMC?

Talk with an accredited Cyber AB Registered Provider Organization.
Get an actionable first step in writing within 30 minutes.

Book a Discovery Call → Call (323) 410-5941

SC **Secure-Centric**

Cyber AB Registered Provider Organization (RPO) dedicated strictly to defense contractor CMMC and NIST SP 800-171 compliance.

📍 Los Angeles, California
info@secure-centric.com
(323) 410-5941

Cyber AB RPO #3942 Inc. 5000 #452

SERVICES
- CMMC Consulting
- NIST SP 800-171 Compliance
- Readiness Assessments
- Gap & Mock Assessments
- Virtual CISO (vCISO)

LEARN & PILLARS
- CMMC Complete Guide
- CMMC Level 2 Guide
- NIST SP 800-171 Explained
- Controlled Unclassified Info
- The 8-Step CMMC Process
- What is a CMMC RPO?

RESOURCES & TOOLS
- Level 2 (110 Controls) Checklist
- Unmarked CUI Checklist
- Level 1 Readiness Checklist

DIB INTELLIGENCE

Get critical rulemaking updates on DFARS 252.204-7021 and CMMC enforcement timelines.

Your work email

Subscribe →

Secure-Centric is an accredited Cyber AB Registered Provider Organization (RPO). We provide cybersecurity readiness preparation, documentation, and advisory services. We are not a Certified Third-Party Assessment Organization (C3PAO) and do not issue official CMMC certifications.

// ABOUT SECURE-CENTRIC

About Secure-Centric: why defense contractors choose us

Secure-Centric is a Cyber AB Registered Provider Organization that only does CMMC and NIST SP 800-171. Meet the team, our results and what clients say.

Book a Discovery Call → Explore Services →

// SECTION EXPLAINER

Our mission

CMMC (Cybersecurity Maturity Model Certification) is the Department of War standard ensuring defense subcontractors safeguard Federal Contract Information (FCI) and Controlled Unclassified Information (CUI).

Under 32 CFR Part 170 and DFARS 252.204-7021, all contractors handling CUI must achieve Level 2 compliance against the 110 requirements of NIST SP 800-171 Rev 2 before contract award.

What makes Secure-Centric different

Cyber AB Registered Provider Organization

Accredited advisory guidance and deliverable frameworks.

Explore Resource →

CMMC and NIST SP 800-171 only

Accredited advisory guidance and deliverable frameworks.

Explore Resource →

Client track record

Accredited advisory guidance and deliverable frameworks.

Explore Resource →

Assessment pass record

Accredited advisory guidance and deliverable frameworks.

Explore Resource →

// VERIFIED TRACK RECORD

Our results

100% C3PAO first-time pass record across defense primes and subcontractors nationwide.

120+
Defense Contractors Prepared
Guided across 45 states protecting $2.4B in active DoD solicitations.

100%
C3PAO First-Time Pass Rate
Zero clients failed an official external third-party audit after readiness sign-off.

3 Weeks
On-Site Walkthrough Guarantee
In-person facility inspection of server rooms and shop-floor enclaves.

Flat-Fee
Fixed Transparent Scope
Zero hourly billing surprises, travel markups, or tool licensing kickbacks.

// CLIENT REVIEWS

What our clients say

Real feedback from C-level executives and IT leadership across the defense industrial base.

01 “

Secure-Centric gave us absolute clarity on what was inside our CUI boundary and what wasn't. We passed our official C3PAO Level 2 assessment on the first attempt with zero open items.

AL **Alex Liu**
IT Manager, Tower Semiconductor

02 “

Their team was on site at our facility within two weeks. They didn't hand us generic compliance templates—they helped configure our actual firewalls, SIEM, and author an ironclad SSP.

PS **Patrick Shaw**
Cyber Security Analyst, Safran Federal Systems

03 “

Most consultants sell managed IT products. Secure-Centric provided strictly independent advisory. They worked directly with our internal team and existing MSP without conflicts.

ROL **Rafael Omar Lemus**
IT Director, Goodwin & Associates

04 “

I would like to thank Secure-Centric and Desmond Thompson, who guided us through the preparation stages for the certification, even before the external assessment.

RA **Regina Amosi**
CISO, Tower Semiconductor
Shared publicly on LinkedIn

05 “

From scoping out shop-floor test equipment to submitting our SPRS score defense, Secure-Centric made what felt like an impossible 110-control standard manageable.

AL **Albert Leon**
CIO, HRD Aero Systems
Shared publicly on LinkedIn

Credentials and badges

Cyber AB RPO

Accredited advisory guidance and deliverable frameworks.

Explore Resource →

Inc. 5000 #452 (2025)

Accredited advisory guidance and deliverable frameworks.

Explore Resource →

[Next badge]

Accredited advisory guidance and deliverable frameworks.

Explore Resource →

// DEFENSE SPECIALISTS

The team

Accredited Cyber AB Registered Practitioners with decades of technical engineering and audit defense experience.

JC
✓ Cyber AB RP

Jake "EJ" Celler

Founder & Lead Registered Practitioner (RP)

15+ years guiding defense industrial base contractors through NIST SP 800-171, DFARS 7012, and CMMC. Accredited Cyber AB Registered Practitioner with 100% C3PAO pass record.

SP
✓ Cyber AB RP

Son Phan

VP Operations & Compliance Director

Specialist in CUI scoping boundaries, IT/OT enclave segmentation, and federal acquisition compliance architectures for aerospace and defense manufacturers.

RP
✓ Cyber AB RP

Senior Registered Practitioners

Audit Defense & Technical Implementation Leads

Former DoD assessment leads, CISSPs, and CMMC Certified Professionals conducting in-person facility walkthroughs, technical mock audits, and assessor interviews.

// CORE PRINCIPLES & INDICATORS

How we work

Principles, not process: independent advice, on site by default, plain English, we never assess clients we advise.

✓ Independent Advice

We do not sell firewalls, MSP services, or software licenses. Our recommendations are 100% objective and tailored to your existing IT footprint.

✓ On Site by Default

We conduct physical facility walkthroughs in person. You cannot verify CMMC compliance over a Zoom screen—we inspect server rooms, wiring closets, and shop floors.

✓ Plain English

No impenetrable jargon. We translate 320 assessment objectives into clear operational steps your executives, engineers, and shop foremen understand.

✓ Strict Conflict Separation

We never assess clients we advise. Under Cyber AB rules, we are strictly an RPO advisor so our loyalty is 100% with defending your organization.

// FREQUENTLY ASKED QUESTIONS

Common questions

Still have questions regarding your specific CMMC clauses or audit dates? Speak directly with our lead Registered Practitioner.

Book a Discovery Call →

Where is Secure-Centric based? ×

Our Cyber AB Registered Practitioners conduct in-depth scoping and compliance reviews to guarantee defensible alignment with Department of War standards.

Do you sell tools or managed IT? +

How long have you worked on CMMC? +

Planning to get started on CMMC?

Talk with an accredited Cyber AB Registered Provider Organization.
Get an actionable first step in writing within 30 minutes.

Book a Discovery Call → Call (323) 410-5941

Secure-Centric is an accredited Cyber AB Registered Provider Organization (RPO). We provide cybersecurity readiness preparation, documentation, and advisory services. We are not a Certified Third-Party Assessment Organization (C3PAO) and do not issue official CMMC certifications.

// CMMC COMPLIANCE SERVICES · WHAT WE DO

CMMC compliance, done with you on site: from scoping to your annual affirmation

One engagement, run on site with your team: we scope, assess, guide the fixes, write the documents with you and prepare you for assessment day, then help you keep it current.

Book a Discovery Call → Explore Every Phase ↓

- Cyber AB RPO · CPN #3942
- Inc. 5000 Honoree
- 100% C3PAO Pass Record

ENGAGEMENT AT A GLANCE

The 6 Delivery Phases

1. Scope and site visit
2. Assess
3. Guide the fixes
4. Document
5. Prepare for assessment
6. Maintain and affirm

KEY DELIVERABLES YOU KEEP:

- Scope + data-flow diagram
- Ranked findings + SPRS estimate
- Remediation plan
- SSP, policies, POA&M
- Evidence index
- Annual affirmation pack

// SECTION EXPLAINER

What a CMMC compliance engagement is

CMMC (Cybersecurity Maturity Model Certification) is the Department of War standard ensuring defense subcontractors safeguard Federal Contract Information (FCI) and Controlled Unclassified Information (CUI).

Under 32 CFR Part 170 and DFARS 252.204-7021, all contractors handling CUI must achieve Level 2 compliance against the 110 requirements of NIST SP 800-171 Rev 2 before contract award.

// PHASE-BY-PHASE EXECUTION

What we do, phase by phase

Our structured 6-phase advisory engagement ensures every control is scoped, addressed, and documented with precision before your official C3PAO assessment date.

01 PHASE 01 // ADVISORY MILESTONE

Scope and site visit

Find where FCI and CUI live; draw the boundary

DELIVERABLES YOU KEEP
Scope document, asset list, data-flow diagram

WHO IS INVOLVED: Executive Sponsor + IT Lead

Phase Details →

02 PHASE 02 // ADVISORY MILESTONE

Assess

Check all 110 requirements against how you really work; optional mock day

DELIVERABLES YOU KEEP
Ranked findings, estimated SPRS score

WHO IS INVOLVED: System Admins + Operations Lead

Phase Details →

03 PHASE 03 // ADVISORY MILESTONE

Guide the fixes

Prioritise fixes by risk and score; advise your IT/MSP

DELIVERABLES YOU KEEP
Remediation plan with owners and dates

WHO IS INVOLVED: Internal IT / MSP Partner

Phase Details →

04 PHASE 04 // ADVISORY MILESTONE

Document

Write the SSP, policies, procedures and POA&M with you

DELIVERABLES YOU KEEP
Assessor-ready SSP, policies, POA&M

WHO IS INVOLVED: Technical Authors + Security Lead

Phase Details →

05 PHASE 05 // ADVISORY MILESTONE

Prepare for assessment

Readiness review, evidence check, assessment-day support

DELIVERABLES YOU KEEP
Evidence index, readiness sign-off

WHO IS INVOLVED: All Systems Custodians

Phase Details →

06 PHASE 06 // ADVISORY MILESTONE

Maintain and affirm

Keep scores, evidence and documents current; annual affirmation support (vCISO)

DELIVERABLES YOU KEEP
Current SSP, annual affirmation

WHO IS INVOLVED: Affirming Official + vCISO

Phase Details →

// CLEAR DIVISION OF RESPONSIBILITIES

Secure-Centric versus your MSP

Defense contractors frequently ask: *"Can our MSP do this alone?"* Here is how an accredited Cyber AB RPO works alongside your existing technical team without overlap.

ACCREDITED RPO ADVISOR   SC

What Secure-Centric does

We lead compliance governance, boundary scoping, document authorship, and assessor defense.

- ✓ Scopes the FCI & CUI boundary to minimize audit cost and timeline
- ✓ Performs formal gap analysis against all 110 NIST SP 800-171 controls
- ✓ Authors your System Security Plan (SSP) and Plan of Action & Milestones (POA&M)
- ✓ Conducts pre-assessment mock audits simulating C3PAO interview methods
- ✓ Provides 100% vendor-neutral advice (we never resell hardware or antivirus)

Engage Secure-Centric →

OPERATIONAL EXECUTION

What your MSP does

Your IT team implements physical and digital configurations to satisfy our technical requirements.

- ✓ Implements technical IT changes (MFA, firewalls, server patching, endpoint agents)
- ✓ Deploys hardware tokens, encrypted laptops, and network access switches
- ✓ Manages daily user ticketing, desktop support, and password resets
- ✓ Maintains daily backup retention and system uptime monitoring
- ✓ Executes configuration instructions derived from our RPO advisory plan

🤝 **We collaborate directly with your MSP engineers**

⚖ **Crucial Cyber AB Role Separation:** By Department of War regulation, an RPO advises, your MSP configures, and an independent C3PAO assesses. We never assess companies we advise, guaranteeing 100% conflict-free compliance and audit objectivity.

// ENGAGEMENT WORKFLOW

How an engagement starts

3 steps: discovery call → on-site visit and scoping → written plan and scope.

01

Discovery Call

Confidential 30-min scoping call under bilateral NDA to review contract clauses, DFARS flowdowns, and timeline.

02

On-Site Walkthrough & Scoping

Physical inspection of server rooms, shop floor enclaves, and technical architecture to map CUI/FCI boundaries.

03

Written Plan & Scope

Detailed phase-by-phase compliance roadmap with flat-fee pricing, deliverables timeline, and SPRS baseline.

// FREE DOWNLOADABLE RESOURCE

First-Call Prep Checklist (what to have ready)

- ✓ Line-by-line audit objective breakdown with defense-industry scoring weights
- ✓ Assessor evidence artifact templates and dual-source verification matrix
- ✓ Automated SPRS deduction formulas and deficiency priority flags
- ✓ Executive ownership tracker with target closeout dates for internal teams

PDF / EXCEL WORKBOOK
First-Call Prep Checklist (what to have ready)

Enter corporate email address

Instant Free Download →

Strictly confidential. No spam guarantee.

// COMPREHENSIVE COMPLIANCE ANALYSIS

Long-form sections

Repeating text-section block (unique to this page).

§ 1 Level 1 and Level 2 engagements are different jobs

Ensuring full compliance with level 1 and level 2 engagements are different jobs requires a meticulous, defensible methodology grounded in NIST SP 800-171A. Defense contractors frequently encounter severe delays when assuming standard commercial IT practices satisfy Department of War cybersecurity criteria.

Our Registered Practitioners examine every requirement through the lens of a certified C3PAO auditor. We establish clear asset classifications—separating CUI assets, Security Protection Assets (SPAs), Contractor Risk Managed Assets (CRMAs), and Specialized Assets—to ensure your scope remains defensible without placing unnecessary financial burden on your organization.

§ 2 How long an engagement takes, and what changes it

Ensuring full compliance with how long an engagement takes, and what changes it requires a meticulous, defensible methodology grounded in NIST SP 800-171A. Defense contractors frequently encounter severe delays when assuming standard commercial IT practices satisfy Department of War cybersecurity criteria.

Our Registered Practitioners examine every requirement through the lens of a certified C3PAO auditor. We establish clear asset classifications—separating CUI assets, Security Protection Assets (SPAs), Contractor Risk Managed Assets (CRMAs), and Specialized Assets—to ensure your scope remains defensible without placing unnecessary financial burden on your organization.

§ 3 What we will ask you on the first call

Ensuring full compliance with what we will ask you on the first call requires a meticulous, defensible methodology grounded in NIST SP 800-171A. Defense contractors frequently encounter severe delays when assuming standard commercial IT practices satisfy Department of War cybersecurity criteria.

Our Registered Practitioners examine every requirement through the lens of a certified C3PAO auditor. We establish clear asset classifications—separating CUI assets, Security Protection Assets (SPAs), Contractor Risk Managed Assets (CRMAs), and Specialized Assets—to ensure your scope remains defensible without placing unnecessary financial burden on your organization.

§ 4 How you will hear from us

Ensuring full compliance with how you will hear from us requires a meticulous, defensible methodology grounded in NIST SP 800-171A. Defense contractors frequently encounter severe delays when assuming standard commercial IT practices satisfy Department of War cybersecurity criteria.

Our Registered Practitioners examine every requirement through the lens of a certified C3PAO auditor. We establish clear asset classifications—separating CUI assets, Security Protection Assets (SPAs), Contractor Risk Managed Assets (CRMAs), and Specialized Assets—to ensure your scope remains defensible without placing unnecessary financial burden on your organization.

// FREQUENTLY ASKED QUESTIONS

Common questions

Still have questions regarding your specific CMMC clauses or audit dates? Speak directly with our lead Registered Practitioner.

Book a Discovery Call →

What does a CMMC consultant do? ×

Our Cyber AB Registered Practitioners conduct in-depth scoping and compliance reviews to guarantee defensible alignment with Department of War standards.

How is a CMMC compliance engagement priced? +

Can we start with one part, like the SSP? +

What do we own at the end? +

What is the difference between an RPO, a consultant and an advisor? +

// KNOWLEDGE ECOSYSTEM

Related pages

Explore related compliance frameworks, staging guides, and scoping resources.

GUIDE →
CMMC Complete Guide
Everything defense contractors need to know about levels, rulemaking, and audits.

GUIDE →
CMMC Level 2 Guide
110 requirements across 14 families: technical details and self vs C3PAO rules.

GUIDE →
NIST SP 800-171 Explained
The technical foundation of CMMC Level 2 and DFARS 7012 requirements.

GUIDE →
CMMC Enclave Advisory
How shrinking your CUI scope saves months of time and tens of thousands in audit costs.

Planning to get started on CMMC?

Talk with an accredited Cyber AB Registered Provider Organization.
Get an actionable first step in writing within 30 minutes.

Book a Discovery Call →   Call (323) 410-5941

// CMMC CONSULTING · WHO WE HELP

CMMC consulting for defense subcontractors, suppliers and manufacturers

If your contract puts FCI or CUI in your hands, CMMC applies to you. Pick the one that sounds like you and follow the path built for it.

Book a Discovery Call →

SELECT YOUR SITUATION

Subcontractor or supplier
See Your Path →

Small or mid-size manufacturer
See Your Path →

Stuck or starting over
See Your Path →

Need an RPO before a C3PAO assessment
See Your Path →

Not sure? Start with your contract tier below ↓

// COMPLIANCE TIERS

By CMMC level: where your contract puts you

Level 1

Level 1 Requirement

FCI only · 15 requirements · annual self-assessment

Explore Level Roadmap →

Level 2 (self)

Level 2 (self) Requirement

CUI · 110 requirements · self-assessment + SPRS

Explore Level Roadmap →

Level 2 (C3PAO)

Level 2 (C3PAO) Requirement

CUI · 110 requirements · third-party certification

Explore Level Roadmap →

Level 3

Level 3 Requirement

Rare · named by the contracting officer · government-led

Explore Level Roadmap →

// EXECUTIVE PERSONAS

By role: what each buyer needs from us

Owner / CEO (Affirming Official)

Signs the annual affirmation; worried about contracts and False Claims Act risk

IT manager or MSP

Capable generalist; unsure how assessors judge evidence or what is in scope

Contracts / compliance lead

Fielding prime questionnaires and solicitation clauses; needs dates and documents

Engineering / operations lead

Owns the drawings and specs (CUI); needs rules that do not stop production

// DEFENSE INDUSTRIAL BASE (DIB)

By position in the defense supply chain

Where defense contractors sit in the DoD supply chain and what triggers compliance.

Prime Contractor

TYPICAL TRIGGER:
Mandated directly in primary DoD solicitation (DFARS 252.204-7021).

TARGET LEVEL:
CMMC Level 2 (C3PAO) or Level 3

FIRST ACTION:
Enterprise scoping & supplier compliance monitoring system.

Explore Your Path →

Tier 1-2 Subcontractor

TYPICAL TRIGGER:
Prime vendor requires CMMC certification as a condition of subcontract award.

TARGET LEVEL:
CMMC Level 2 (C3PAO Certified)

FIRST ACTION:
Facility walkthrough and CUI boundary segmentation.

Explore Your Path →

Small Supplier / Machine Shop

TYPICAL TRIGGER:
Receives engineering CAD files, technical specs, or build-to-print drawings.

TARGET LEVEL:
CMMC Level 2 (Enclave or Company-Wide)

FIRST ACTION:
Evaluate managed CUI enclave vs whole-network remediation.

Explore Your Path →

Services & Software Provider

TYPICAL TRIGGER:
Provides cloud hosting, engineering support, or IT services touching CUI/FCI.

TARGET LEVEL:
CMMC Level 1 or Level 2

FIRST ACTION:
FedRAMP Moderate equivalence and boundary validation.

Explore Your Path →

// DEFENSE SUPPLY CHAIN PATHS

Your path, step by step

Sequential milestones tailored to your exact role in the Defense Industrial Base.

Prime Contractors

Must achieve Level 2 certification and enforce supplier flowdowns.

1. Readiness Check → 2. Enclave Scoping → 3. SSP & POA&M → 4. C3PAO Audit

Tier 1 & Tier 2 Subcontractors

Facing urgent prime contractor questionnaires and DFARS 7012 clauses.

1. Gap Assessment → 2. Remediation Advisory → 3. Documentation → 4. Audit Defense

Small Machine Shops & Suppliers

Receiving CUI engineering drawings with limited internal IT staff.

1. CUI Enclave Setup → 2. Policy Suite → 3. Readiness Review → 4. SPRS Defense

Software & Cloud Service Providers

Providing software touching DoD systems requiring FedRAMP Moderate equivalence.

1. Cloud Scoping → 2. FedRAMP Verification → 3. SSP Authoring → 4. Certification

// CORE PRINCIPLES & INDICATORS

Signs you need a CMMC consultant now

Stuck or starting over: unknown or low SPRS score · SSP copied from a template · POA&M items with no owner or date · a prime questionnaire with a deadline · CMMC clause in a solicitation and no plan · a past self-assessment that went badly · nobody owns CMMC.

✓ **Prime Contractor CMMC Questionnaire Received**
Your prime asks for your SPRS score, SSP date, or CMMC certification roadmap within 30 days.

✓ **Upcoming DoD RFP with DFARS 7021**
Contract renewals require verified CMMC compliance as a prerequisite for submission.

✓ **Negative or Uncalculated SPRS Score**
Your DoD score is below zero or based on guesswork rather than the official assessment guide.

✓ **Uncertainty on CUI Boundaries**
You cannot definitively prove which servers, endpoints, and employees touch defense data.

✓ **MSP Unfamiliar with NIST 800-171A**
Your IT provider manages day-to-day help desk but lacks defense compliance engineering expertise.

// OBJECTIVE COMPARISON

Who needs an RPO, and who may not

Honest two columns: companies that really need RPO-level help (Level 2 with CUI, no in-house security lead, assessment date set) vs those who may manage alone (Level 1 with capable IT, a good template and time).

Who Needs an RPO

Companies facing high-stakes DoD contract requirements where audit failure carries severe operational or financial risk.

- ✓ Defense contractors with DFARS 252.204-7012 or 7021 in contracts
- ✓ Subcontractors receiving engineering drawings containing CUI
- ✓ Companies with upcoming prime contractor audit deadlines
- ✓ Organizations lacking dedicated in-house cybersecurity compliance staff
- ✓ Contractors preparing for an official C3PAO Level 2 certification

Who May Manage In-House

Small suppliers with limited Federal Contract Information (FCI) and simple, standard IT environments.

- ○ Level 1 contractors handling FCI only (15 basic safeguarding controls)
- ○ Suppliers with an experienced internal full-time cybersecurity engineer
- ○ Organizations with 12+ months before upcoming DoD contract solicitations
- ○ Companies operating completely air-gapped from federal networks

// DECISION FRAMEWORK

How to choose a CMMC consultant: 7 checks

Check every qualification before engaging any CMMC advisory firm.

☑ **01.** Accredited Cyber AB Registered Provider Organization (RPO)? ✓ Secure-Centric Verified
☑ **02.** Employs active, vetted Registered Practitioners (RPs)? ✓ Secure-Centric Verified
☑ **03.** Conducts in-person on-site walkthroughs (not just Zoom)? ✓ Secure-Centric Verified
☑ **04.** 100% independent advisory (does not sell managed IT/tools)? ✓ Secure-Centric Verified
☑ **05.** Fixed flat-fee engagement pricing (no hidden scope creep)? ✓ Secure-Centric Verified
☑ **06.** Guarantees C3PAO first-time pass readiness in writing? ✓ Secure-Centric Verified
☑ **07.** Signs bilateral defense-grade NDA within 2 hours? ✓ Secure-Centric Verified

7 / 7
FULL COMPLIANCE

100% Verified CMMC Advisory Standard

Secure-Centric satisfies all 7 rigorous criteria: Cyber AB RPO accreditation, active Registered Practitioners, on-site audits, 100% independent conflict-free advice, flat-fee pricing, and guaranteed readiness.

Book a Discovery Call →

// FREE DOWNLOADABLE RESOURCE

7-check consultant scorecard

- ✓ Line-by-line audit objective breakdown with defense-industry scoring weights
- ✓ Assessor evidence artifact templates and dual-source verification matrix
- ✓ Automated SPRS deduction formulas and deficiency priority flags
- ✓ Executive ownership tracker with target closeout dates for internal teams

PDF / EXCEL WORKBOOK
7-check consultant scorecard

Enter corporate email address

Instant Free Download →

Strictly confidential. No spam guarantee.

// FREQUENTLY ASKED QUESTIONS

Common questions

Still have questions regarding your specific CMMC clauses or audit dates? Speak directly with our lead Registered Practitioner.

Book a Discovery Call →

Do I need a CMMC consultant, or can I do it in-house? ×

Our Cyber AB Registered Practitioners conduct in-depth scoping and compliance reviews to guarantee defensible alignment with Department of War standards.

How do I choose a CMMC consultant? +

Which firm gives the best CMMC preparation advice? +

Do small suppliers and machine shops need a CMMC consultant? +

Do primes need help with their supply chain? +

// KNOWLEDGE ECOSYSTEM

Related pages

Explore related compliance frameworks, staging guides, and scoping resources.

GUIDE →
CMMC Complete Guide
Everything defense contractors need to know about levels, rulemaking, and audits.

GUIDE →
CMMC Level 2 Guide
110 requirements across 14 families: technical details and self vs C3PAO rules.

GUIDE →
NIST SP 800-171 Explained
The technical foundation of CMMC Level 2 and DFARS 7012 requirements.

GUIDE →
CMMC Enclave Advisory
How shrinking your CUI scope saves months of time and tens of thousands in audit costs.

Planning to get started on CMMC?

Talk with an accredited Cyber AB Registered Provider Organization.
Get an actionable first step in writing within 30 minutes.

Book a Discovery Call → Call (323) 410-5941

SC Secure-Centric

Cyber AB Registered Provider Organization (RPO) dedicated strictly to defense contractor CMMC and NIST SP 800-171 compliance.

📍 Los Angeles, California
info@secure-centric.com
(323) 410-5941

Cyber AB RPO #3942 Inc. 5000 #452

SERVICES
CMMC Consulting
NIST SP 800-171 Compliance
Readiness Assessments
Gap & Mock Assessments
Virtual CISO (vCISO)

LEARN & PILLARS
CMMC Complete Guide
CMMC Level 2 Guide
NIST SP 800-171 Explained
Controlled Unclassified Info
The 8-Step CMMC Process
What is a CMMC RPO?

RESOURCES & TOOLS
Level 2 (110 Controls) Checklist
Unmarked CUI Checklist
Level 1 Readiness Checklist

DIB INTELLIGENCE
Get critical rulemaking updates on DFARS 252.204-7021 and CMMC enforcement timelines.
Your work email
Subscribe →

Secure-Centric is an accredited Cyber AB Registered Provider Organization (RPO). We provide cybersecurity readiness preparation, documentation, and advisory services. We are not a Certified Third-Party Assessment Organization (C3PAO) and do not issue official CMMC certifications.

HOME / SERVICES / ENGAGEMENT STAGES / CMMC READINESS ASSESSMENT

■ // PART OF CMMC COMPLIANCE · CMMC READINESS ASSESSMENT

CMMC readiness assessment: know your gaps and your score before the official assessment

See every gap and your estimated NIST SP 800-171 score before an assessor does. We come to your site; this is not the official assessment.

Book a Discovery Call → What you leave with ↓

■ // DIRECT ADVISORY

Here is exactly what you receive on your confidential 30-minute scoping review:

- ✓ Where you stand today against NIST 800-171
- ✓ Which level and scoping boundary fits your contracts
- ✓ A concrete, written first step before committing budget

Book Discovery Call →

STAGE **Readiness review** Part of CMMC compliance services →

YOU'RE AT THIS STAGE IF… You know CMMC applies but not where you stand or what is in scope. See the full CMMC 8-step process →

■ // DETAILED REVIEW STAGES

What happens in the readiness review

5 vertical steps; columns: step · who is involved · what you get. This stage only: what happens, who is in the room, what you leave with.

#	REVIEW ACTIVITY	WHO IS INVOLVED	WHAT YOU LEAVE WITH
01	**Scoping Re-Verification**	Secure-Centric RP + IT Lead	**Validated Asset Boundary Diagram**
02	**Documentation Deep Dive**	Secure-Centric + Quality Director	**SSP & Policy Completeness Scorecard**
03	**Assessor Interview Simulation**	Department Leads & System Admins	**Interview Readiness Notes & FAQ Prep**
04	**Live Technical Testing**	Secure-Centric + Network Admin	**MFA, Encryption & Logging Validation**
05	**Official Readiness Sign-Off**	Secure-Centric Principals + C-Suite	**Audit Go/No-Go Recommendation Report**

■ // FREE DOWNLOADABLE RESOURCE

CMMC Readiness Checklist

- ✓ Line-by-line audit objective breakdown with defense-industry scoring weights
- ✓ Assessor evidence artifact templates and dual-source verification matrix
- ✓ Automated SPRS deduction formulas and deficiency priority flags
- ✓ Executive ownership tracker with target closeout dates for internal teams

PDF / EXCEL WORKBOOK
CMMC Readiness Checklist

Enter corporate email address
Instant Free Download →
Strictly confidential. No spam guarantee.

■ // IN-PERSON VERIFICATION

On-site visit

An in-person walkthrough is step 1 of every Secure-Centric engagement. You cannot verify CMMC compliance over a web call.

- ✓ Physical inspection of server rooms, wiring closets, and environmental controls
- ✓ Direct inspection of visitor badges, physical escort logs, and secure storage containers
- ✓ Verification of shop-floor CNC machines, 3D printers, and test equipment network isolation
- ✓ Face-to-face interviews with system administrators and department heads to confirm actual practices

■ // OBJECTIVE COMPARISON

Readiness assessment versus the official assessment

Two columns.

RPO Readiness Assessment

A collaborative, advisory diagnostic that finds gaps, tests controls, and prepares your team to pass.

- ✓ Diagnostic and preparatory — identifies what needs fixing
- ✓ Collaborative: we work alongside your team and MSP
- ✓ Includes remediation advice and technical recommendations
- ✓ Covers evidence gathering and assessor interview rehearsal
- ✓ Guarantees readiness before committing to audit costs

Official C3PAO Assessment

A formal, independent third-party evaluation that issues your official pass/fail certification.

- ○ Evaluative only — strictly cannot provide advice or remediation
- ○ Conducted by independent Certified CMMC Assessors (CCAs)
- ○ Failures are recorded and can delay contract awards
- ○ Requires fully mature evidence operational for at least 90 days
- ○ High financial cost with zero do-overs if major deficiencies exist

■ // COMPREHENSIVE COMPLIANCE ANALYSIS

Long-form sections

Repeating text-section block.

§ 1 What a readiness assessment looks at

Ensuring full compliance with what a readiness assessment looks at requires a meticulous, defensible methodology grounded in NIST SP 800-171A. Defense contractors frequently encounter severe delays when assuming standard commercial IT practices satisfy Department of War cybersecurity criteria.

Our Registered Practitioners examine every requirement through the lens of a certified C3PAO auditor. We establish clear asset classifications—separating CUI assets, Security Protection Assets (SPAs), Contractor Risk Managed Assets (CRMAs), and Specialized Assets—to ensure your scope remains defensible without placing unnecessary financial burden on your organization.

§ 2 Preparing for the assessor (incl. DIBCAC/JSVA note if offered)

Ensuring full compliance with preparing for the assessor (incl. dibcac/jsva note if offered) requires a meticulous, defensible methodology grounded in NIST SP 800-171A. Defense contractors frequently encounter severe delays when assuming standard commercial IT practices satisfy Department of War cybersecurity criteria.

Our Registered Practitioners examine every requirement through the lens of a certified C3PAO auditor. We establish clear asset classifications—separating CUI assets, Security Protection Assets (SPAs), Contractor Risk Managed Assets (CRMAs), and Specialized Assets—to ensure your scope remains defensible without placing unnecessary financial burden on your organization.

§ 3 From readiness to the gap assessment

Ensuring full compliance with from readiness to the gap assessment requires a meticulous, defensible methodology grounded in NIST SP 800-171A. Defense contractors frequently encounter severe delays when assuming standard commercial IT practices satisfy Department of War cybersecurity criteria.

Our Registered Practitioners examine every requirement through the lens of a certified C3PAO auditor. We establish clear asset classifications—separating CUI assets, Security Protection Assets (SPAs), Contractor Risk Managed Assets (CRMAs), and Specialized Assets—to ensure your scope remains defensible without placing unnecessary financial burden on your organization.

§ 4 Who should be involved

Ensuring full compliance with who should be involved requires a meticulous, defensible methodology grounded in NIST SP 800-171A. Defense contractors frequently encounter severe delays when assuming standard commercial IT practices satisfy Department of War cybersecurity criteria.

Our Registered Practitioners examine every requirement through the lens of a certified C3PAO auditor. We establish clear asset classifications—separating CUI assets, Security Protection Assets (SPAs), Contractor Risk Managed Assets (CRMAs), and Specialized Assets—to ensure your scope remains defensible without placing unnecessary financial burden on your organization.

§ 5 Signs you are ready for the official assessment

Ensuring full compliance with signs you are ready for the official assessment requires a meticulous, defensible methodology grounded in NIST SP 800-171A. Defense contractors frequently encounter severe delays when assuming standard commercial IT practices satisfy Department of War cybersecurity criteria.

Our Registered Practitioners examine every requirement through the lens of a certified C3PAO auditor. We establish clear asset classifications—separating CUI assets, Security Protection Assets (SPAs), Contractor Risk Managed Assets (CRMAs), and Specialized Assets—to ensure your scope remains defensible without placing unnecessary financial burden on your organization.

■ // FREQUENTLY ASKED QUESTIONS

Common questions

Still have questions regarding your specific CMMC clauses or audit dates? Speak directly with our lead Registered Practitioner.

Book a Discovery Call →

How do I prepare for a CMMC assessment? ×

Our Cyber AB Registered Practitioners conduct in-depth scoping and compliance reviews to guarantee defensible alignment with Department of War standards.

Is a readiness assessment the same as a C3PAO assessment? +

What does a CMMC readiness assessment cover? +

How much does a CMMC assessment cost? +

Who is the best CMMC assessment provider for a subcontractor? +

How long does a readiness assessment take? +

■ // KNOWLEDGE ECOSYSTEM

Related pages

Explore related compliance frameworks, staging guides, and scoping resources.

GUIDE →
CMMC Complete Guide
Everything defense contractors need to know about levels, rulemaking, and audits.

GUIDE →
CMMC Level 2 Guide
110 requirements across 14 families: technical details and self vs C3PAO rules.

GUIDE →
NIST SP 800-171 Explained
The technical foundation of CMMC Level 2 and DFARS 7012 requirements.

GUIDE →
CMMC Enclave Advisory
How shrinking your CUI scope saves months of time and tens of thousands in audit costs.

Planning to get started on CMMC?

Talk with an accredited Cyber AB Registered Provider Organization.
Get an actionable first step in writing within 30 minutes.

Book a Discovery Call → Call (323) 410-5941

Secure-Centric is an accredited Cyber AB Registered Provider Organization (RPO). We provide cybersecurity readiness preparation, documentation, and advisory services. We are not a Certified Third-Party Assessment Organization (C3PAO) and do not issue official CMMC certifications.

HOME / SERVICES / ENGAGEMENT STAGES / CMMC GAP AND MOCK ASSESSMENT

// PART OF CMMC COMPLIANCE · GAP AND MOCK ASSESSMENT

CMMC gap assessment and mock assessment for defense contractors

Every NIST SP 800-171 requirement checked against how you really work, a ranked fix list, and a rehearsal of assessment day if you want one.

Book a Discovery Call → See a sample finding ↓

// DIRECT ADVISORY

Here is exactly what you receive on your confidential 30-minute scoping review:

- ✓ Where you stand today against NIST 800-171
- ✓ Which level and scoping boundary fits your contracts
- ✓ A concrete, written first step before committing budget

Book Discovery Call →

STAGE **Gap assessment + readiness review** Part of CMMC compliance services →

YOU'RE AT THIS STAGE IF… You have an SSP and a score and want to know how an assessor would grade you before it counts. See the full CMMC 8-step process →

// CORE PRINCIPLES & INDICATORS

What you receive from the gap assessment

List of points.

- ✓ **Comprehensive 110-Control Findings Register**
  Detailed spreadsheet mapping all 320 assessment objectives with pass, fail, or partial statuses.
- ✓ **Defensible DoD SPRS Score Calculation**
  Mathematically verified score (-203 to +110) calculated under official DoD scoring methodology.
- ✓ **Prioritized Remediation Roadmap**
  Step-by-step technical and procedural fix schedule with estimated costs and milestone dates.
- ✓ **Executive Presentation & Briefing**
  Clear summary deck for board and C-suite detailing contract risk, budget requirements, and timelines.

Sample findings table

REQUIREMENT	STATUS	RISK	FIX	OWNER
AC.L2-3.1.1 (Access Control & Boundary Protection)	Non-Compliant	High (-5 SPRS)	Enforce centralized MFA & remove shared admin credentials	Lead SecOps Engineer
IA.L2-3.5.3 (Multifactor Authentication)	Partially Met	High (-5 SPRS)	Deploy FIPS 140-2 validated hardware tokens across all privileged sessions	IT Director
SC.L2-3.13.11 (FIPS-Validated Cryptography)	Non-Compliant	Medium (-3 SPRS)	Enable BitLocker with certified FIPS 140-2 cryptographic modules	Systems Administrator
AU.L2-3.3.1 (Audit Logging & SIEM Review)	Compliant	Low (0 SPRS)	Weekly automated audit log analysis and tamper-proof log forwarding verified	Security Analyst

// FREE DOWNLOADABLE RESOURCE

Assessment-Day Prep Checklist

- ✓ Line-by-line audit objective breakdown with defense-industry scoring weights
- ✓ Assessor evidence artifact templates and dual-source verification matrix
- ✓ Automated SPRS deduction formulas and deficiency priority flags
- ✓ Executive ownership tracker with target closeout dates for internal teams

PDF / EXCEL WORKBOOK
Assessment-Day Prep Checklist

Enter corporate email address
Instant Free Download →
Strictly confidential. No spam guarantee.

Gap, mock, readiness or pre-assessment: which one?

	GAP	MOCK	READINESS	PRE-ASSESSMENT
Gap Assessment	Identify missing controls against NIST 800-171	Secure-Centric RPs	SPRS Score + Itemized Remediation Plan	
Remediation Review	Verify fixes and close out open POA&M items	Secure-Centric + IT	Updated SSP + Validated Evidence Binder	
Mock Assessment	Full rehearsal simulating exact C3PAO audit day	Senior Lead RP	Go/No-Go Decision + Assessor Defense Prep	
Official Assessment	Issue formal Level 2 CMMC certification	Accredited C3PAO	Official DoD CMMC Certification (3 Years)	

// ENGAGEMENT WORKFLOW

What happens in the gap and mock assessment

4 numbered steps. This stage only: what happens, who is in the room, what you leave with.

01
Objective Scoping
Define boundaries and collect existing network architecture, policies, and hardware inventories.

02
110-Control Evidence Audit
Deep dive into 320 assessment objectives with interviews, technical tests, and artifact verification.

03
SPRS Scoring & Findings
Calculate official defensible DoD score (-203 to +110) with itemized deficiency register.

04
Actionable Remediation Plan
Prioritized fixes with cost estimates, technical specifications, and POA&M draft.

// COMPREHENSIVE COMPLIANCE ANALYSIS

Long-form sections

Repeating text-section block.

§ 1 Common gaps we find

Ensuring full compliance with common gaps we find requires a meticulous, defensible methodology grounded in NIST SP 800-171A. Defense contractors frequently encounter severe delays when assuming standard commercial IT practices satisfy Department of War cybersecurity criteria.

Our Registered Practitioners examine every requirement through the lens of a certified C3PAO auditor. We establish clear asset classifications—separating CUI assets, Security Protection Assets (SPAs), Contractor Risk Managed Assets (CRMAs), and Specialized Assets—to ensure your scope remains defensible without placing unnecessary financial burden on your organization.

§ 2 How evidence is judged

Ensuring full compliance with how evidence is judged requires a meticulous, defensible methodology grounded in NIST SP 800-171A. Defense contractors frequently encounter severe delays when assuming standard commercial IT practices satisfy Department of War cybersecurity criteria.

Our Registered Practitioners examine every requirement through the lens of a certified C3PAO auditor. We establish clear asset classifications—separating CUI assets, Security Protection Assets (SPAs), Contractor Risk Managed Assets (CRMAs), and Specialized Assets—to ensure your scope remains defensible without placing unnecessary financial burden on your organization.

§ 3 How gaps affect your SPRS score

Ensuring full compliance with how gaps affect your sprs score requires a meticulous, defensible methodology grounded in NIST SP 800-171A. Defense contractors frequently encounter severe delays when assuming standard commercial IT practices satisfy Department of War cybersecurity criteria.

Our Registered Practitioners examine every requirement through the lens of a certified C3PAO auditor. We establish clear asset classifications—separating CUI assets, Security Protection Assets (SPAs), Contractor Risk Managed Assets (CRMAs), and Specialized Assets—to ensure your scope remains defensible without placing unnecessary financial burden on your organization.

§ 4 What a mock assessment day feels like

Ensuring full compliance with what a mock assessment day feels like requires a meticulous, defensible methodology grounded in NIST SP 800-171A. Defense contractors frequently encounter severe delays when assuming standard commercial IT practices satisfy Department of War cybersecurity criteria.

Our Registered Practitioners examine every requirement through the lens of a certified C3PAO auditor. We establish clear asset classifications—separating CUI assets, Security Protection Assets (SPAs), Contractor Risk Managed Assets (CRMAs), and Specialized Assets—to ensure your scope remains defensible without placing unnecessary financial burden on your organization.

// FREQUENTLY ASKED QUESTIONS

Common questions

Still have questions regarding your specific CMMC clauses or audit dates? Speak directly with our lead Registered Practitioner.

Book a Discovery Call →

What is a CMMC gap assessment? ×

Our Cyber AB Registered Practitioners conduct in-depth scoping and compliance reviews to guarantee defensible alignment with Department of War standards.

Gap assessment, mock assessment, readiness assessment or pre-assessment: which one? +

What causes the most gaps in NIST 800-171 compliance? +

Who should run my gap assessment? +

How do I reduce the gaps an assessor would find? +

Will I get a score? +

// KNOWLEDGE ECOSYSTEM

Related pages

Explore related compliance frameworks, staging guides, and scoping resources.

GUIDE →
CMMC Complete Guide
Everything defense contractors need to know about levels, rulemaking, and audits.

GUIDE →
CMMC Level 2 Guide
110 requirements across 14 families: technical details and self vs C3PAO rules.

GUIDE →
NIST SP 800-171 Explained
The technical foundation of CMMC Level 2 and DFARS 7012 requirements.

GUIDE →
CMMC Enclave Advisory
How shrinking your CUI scope saves months of time and tens of thousands in audit costs.

Planning to get started on CMMC?

Talk with an accredited Cyber AB Registered Provider Organization.
Get an actionable first step in writing within 30 minutes.

Book a Discovery Call → Call (323) 410-5941

// NIST 800-171 COMPLIANCE

NIST 800-171 compliance services for defense contractors

Yes: DFARS 7012 means you must meet NIST SP 800-171. We assess, guide the fixes and prepare your SSP, POA&M and SPRS score.

Book a Discovery Call → Estimate your score: SPRS checklist ↓

// DIRECT ADVISORY

Here is exactly what you receive on your confidential 30-minute scoping review:

- ✓ Where you stand today against NIST 800-171
- ✓ Which level and scoping boundary fits your contracts
- ✓ A concrete, written first step before committing budget

Book Discovery Call →

// CORE PRINCIPLES & INDICATORS

What we do for NIST SP 800-171

What we deliver for DFARS 7012 contracts: SPRS score you can defend, SSP, POA&M, 7019/7020 support, annual upkeep. The explanation of the standard lives on the NIST 800-171 guide (linked).

DFARS 252.204-7012 Scoping
Identify cyber incident reporting boundaries, FedRAMP Moderate cloud compliance, and CUI handling.

DFARS 252.204-7019 SPRS Scoring
Calculate and defend your Supplier Performance Risk System score before government submission.

DFARS 252.204-7020 DIBCAC Support
Prepare your documentation and staff for potential DoD DIBCAC basic or medium assessments.

Comprehensive System Security Plan (SSP)
Author complete, assessor-ready documentation reflecting all 110 security controls in practice.

// OBJECTIVE COMPARISON

NIST 800-171 versus CMMC

Two columns side by side.

NIST SP 800-171 Standard

The technical cybersecurity standard established by NIST containing 110 controls across 14 security families.

- ✓ Published technical requirements for safeguarding CUI
- ✓ Incorporated into defense contracts via DFARS 252.204-7012
- ✓ Requires entering an SPRS score into the DoD database
- ✓ Allows self-assessment scoring methodology
- ✓ Forms the exact technical baseline for CMMC Level 2

CMMC Framework

The Department of Defense verification and certification program that enforces NIST 800-171 compliance.

- ○ Verification program ensuring contractors actually implement NIST controls
- ○ Introduces mandatory C3PAO third-party audits for Level 2
- ○ Requires annual executive senior official affirmations
- ○ Restricts or eliminates long-term open POA&Ms
- ○ Condition of defense contract award under DFARS 252.204-7021

// FREE DOWNLOADABLE RESOURCE

DFARS 7012 / 7019 / 7020 Contract Clause Checklist

- ✓ Line-by-line audit objective breakdown with defense-industry scoring weights
- ✓ Assessor evidence artifact templates and dual-source verification matrix
- ✓ Automated SPRS deduction formulas and deficiency priority flags
- ✓ Executive ownership tracker with target closeout dates for internal teams

PDF / EXCEL WORKBOOK
DFARS 7012 / 7019 / 7020 Contract Clause Checklist

Enter corporate email address

Instant Free Download →

Strictly confidential. No spam guarantee.

Benefits of getting NIST 800-171 right

Win & Retain DoD Contracts
Satisfy mandatory Section I DFARS contract clauses and qualify for prime contractor supply chain tiers.
Explore Resource →

Defend Your SPRS Score
Establish an auditable score between -203 and +110 that withstands government DIBCAC review.
Explore Resource →

Eliminate False Claims Act Liability
Prevent severe civil liability from submitting inaccurate self-assessment scores to the federal government.
Explore Resource →

Streamline CMMC Level 2 Transition
NIST SP 800-171 is the exact technical baseline for CMMC Level 2—get both done in a single unified engagement.
Explore Resource →

// ENGAGEMENT WORKFLOW

How a NIST 800-171 engagement runs

Numbered steps.

01
Clause Scoping (7012/7019/7020)
Identify federal contract clauses and determine whether basic or specified CUI is received.

02
On-Site Technical Walkthrough
Verify physical access, network perimeter, MFA, and cloud storage compliance.

03
SSP & POA&M Development
Co-author comprehensive System Security Plan and itemized Plan of Action.

04
SPRS Submission Defense
Support entering verified score into DoD Supplier Performance Risk System with audit trail.

// COMPREHENSIVE COMPLIANCE ANALYSIS

Long-form sections

Repeating text-section block.

§ 1 DFARS 7012 and CMMC: do I need both?

Ensuring full compliance with dfars 7012 and cmmc: do i need both? requires a meticulous, defensible methodology grounded in NIST SP 800-171A. Defense contractors frequently encounter severe delays when assuming standard commercial IT practices satisfy Department of War cybersecurity criteria.

Our Registered Practitioners examine every requirement through the lens of a certified C3PAO auditor. We establish clear asset classifications—separating CUI assets, Security Protection Assets (SPAs), Contractor Risk Managed Assets (CRMAs), and Specialized Assets—to ensure your scope remains defensible without placing unnecessary financial burden on your organization.

§ 2 Staying compliant after the first pass

Ensuring full compliance with staying compliant after the first pass requires a meticulous, defensible methodology grounded in NIST SP 800-171A. Defense contractors frequently encounter severe delays when assuming standard commercial IT practices satisfy Department of War cybersecurity criteria.

Our Registered Practitioners examine every requirement through the lens of a certified C3PAO auditor. We establish clear asset classifications—separating CUI assets, Security Protection Assets (SPAs), Contractor Risk Managed Assets (CRMAs), and Specialized Assets—to ensure your scope remains defensible without placing unnecessary financial burden on your organization.

§ 3 Who NIST 800-171 applies to

Ensuring full compliance with who nist 800-171 applies to requires a meticulous, defensible methodology grounded in NIST SP 800-171A. Defense contractors frequently encounter severe delays when assuming standard commercial IT practices satisfy Department of War cybersecurity criteria.

Our Registered Practitioners examine every requirement through the lens of a certified C3PAO auditor. We establish clear asset classifications—separating CUI assets, Security Protection Assets (SPAs), Contractor Risk Managed Assets (CRMAs), and Specialized Assets—to ensure your scope remains defensible without placing unnecessary financial burden on your organization.

§ 4 Common NIST 800-171 pitfalls

Ensuring full compliance with common nist 800-171 pitfalls requires a meticulous, defensible methodology grounded in NIST SP 800-171A. Defense contractors frequently encounter severe delays when assuming standard commercial IT practices satisfy Department of War cybersecurity criteria.

Our Registered Practitioners examine every requirement through the lens of a certified C3PAO auditor. We establish clear asset classifications—separating CUI assets, Security Protection Assets (SPAs), Contractor Risk Managed Assets (CRMAs), and Specialized Assets—to ensure your scope remains defensible without placing unnecessary financial burden on your organization.

// FREQUENTLY ASKED QUESTIONS

Common questions

Still have questions regarding your specific CMMC clauses or audit dates? Speak directly with our lead Registered Practitioner.

Book a Discovery Call →

How do I become NIST 800-171 compliant? ×

Our Cyber AB Registered Practitioners conduct in-depth scoping and compliance reviews to guarantee defensible alignment with Department of War standards.

Is there software that makes me NIST 800-171 compliant? +

Does a small business need NIST 800-171? +

Who can help with NIST 800-171 implementation? +

How do we keep our SPRS score current? +

// KNOWLEDGE ECOSYSTEM

Related pages

Explore related compliance frameworks, staging guides, and scoping resources.

GUIDE →
CMMC Complete Guide
Everything defense contractors need to know about levels, rulemaking, and audits.

GUIDE →
CMMC Level 2 Guide
110 requirements across 14 families: technical details and self vs C3PAO rules.

GUIDE →
NIST SP 800-171 Explained
The technical foundation of CMMC Level 2 and DFARS 7012 requirements.

GUIDE →
CMMC Enclave Advisory
How shrinking your CUI scope saves months of time and tens of thousands in audit costs.

Planning to get started on CMMC?

Talk with an accredited Cyber AB Registered Provider Organization.
Get an actionable first step in writing within 30 minutes.

Book a Discovery Call → Call (323) 410-5941

// PART OF CMMC COMPLIANCE · REMEDIATION ADVISORY

CMMC implementation and remediation advisory for defense contractors

We advise and document; your IT team or MSP makes the changes. Fix the gaps in the order that lifts your score and lowers risk first.

Book a Discovery Call → Who does what ↓

// DIRECT ADVISORY

Here is exactly what you receive on your confidential 30-minute scoping review:

- ✓ Where you stand today against NIST 800-171
- ✓ Which level and scoping boundary fits your contracts
- ✓ A concrete, written first step before committing budget

Book Discovery Call →

STAGE **Remediation** Part of CMMC compliance services →

YOU'RE AT THIS STAGE IF… You have a list of gaps and need them closed in the right order, by the right people. See the full CMMC 8-step process →

// SECTION EXPLAINER

Typical remediation themes

CMMC (Cybersecurity Maturity Model Certification) is the Department of War standard ensuring defense subcontractors safeguard Federal Contract Information (FCI) and Controlled Unclassified Information (CUI).

Under 32 CFR Part 170 and DFARS 252.204-7021, all contractors handling CUI must achieve Level 2 compliance against the 110 requirements of NIST SP 800-171 Rev 2 before contract award.

Our Cyber AB Registered Practitioners conduct on-site facility walkthroughs, map exact CUI boundaries, guide technical remediation, and co-author your assessor-ready System Security Plan (SSP).

// CORE PRINCIPLES & INDICATORS

What you receive during remediation

List of points.

- ✓ **Technical Security Configurations** Direct guidance configuring FIPS-validated encryption, multi-factor authentication, and centralized logging.
- ✓ **Complete Policy & Procedure Suite** 14 customized operational policies governing access control, incident response, and media protection.
- ✓ **Evidence Binder Index** Organized repository of screenshots, logs, and artifacts ready for external assessor review.
- ✓ **Assessor Interview Preparation** Mock interviews training your IT leads and department heads to answer CCA questions confidently.

// DETAILED REVIEW STAGES

What happens during remediation

Vertical steps; columns: step · who does it (Secure-Centric / your IT or MSP) · output. This stage only: what happens, who is in the room, what you leave with.

#	REVIEW ACTIVITY	WHO IS INVOLVED	WHAT YOU LEAVE WITH
01	**POA&M Prioritization**	Secure-Centric + IT Lead	**Weighted Risk Remediation Roadmap**
02	**Technical Fix Guidance**	Your IT/MSP (guided by us)	**MFA, FIPS 140-3 & SIEM Configs**
03	**Boundary Isolation**	Secure-Centric + Network Eng	**Enclave Firewall Rules & Air-Gap Access**
04	**Policy Drafting & SOPs**	Secure-Centric Compliance Team	**14 Core Domain Governance Policies**
05	**Deficiency Closeout Audit**	Lead Registered Practitioner	**Closed POA&M Items & Evidence Binder**

// FREE DOWNLOADABLE RESOURCE

Top 10 CMMC Gaps Checklist

- ✓ Line-by-line audit objective breakdown with defense-industry scoring weights
- ✓ Assessor evidence artifact templates and dual-source verification matrix
- ✓ Automated SPRS deduction formulas and deficiency priority flags
- ✓ Executive ownership tracker with target closeout dates for internal teams

PDF / EXCEL WORKBOOK
Top 10 CMMC Gaps Checklist

Enter corporate email address

Instant Free Download →

Strictly confidential. No spam guarantee.

// DECISION FRAMEWORK

Remediate everywhere, or shrink the scope?

Check every qualification before engaging any CMMC advisory firm.

- ☑ **01.** Accredited Cyber AB Registered Provider Organization (RPO)? ✓ Secure-Centric Verified
- ☑ **02.** Employs active, vetted Registered Practitioners (RPs)? ✓ Secure-Centric Verified
- ☑ **03.** Conducts in-person on-site walkthroughs (not just Zoom)? ✓ Secure-Centric Verified
- ☑ **04.** 100% independent advisory (does not sell managed IT/tools)? ✓ Secure-Centric Verified
- ☑ **05.** Fixed flat-fee engagement pricing (no hidden scope creep)? ✓ Secure-Centric Verified
- ☑ **06.** Guarantees C3PAO first-time pass readiness in writing? ✓ Secure-Centric Verified
- ☑ **07.** Signs bilateral defense-grade NDA within 2 hours? ✓ Secure-Centric Verified

7 / 7
FULL COMPLIANCE

100% Verified CMMC Advisory Standard

Secure-Centric satisfies all 7 rigorous criteria: Cyber AB RPO accreditation, active Registered Practitioners, on-site audits, 100% independent conflict-free advice, flat-fee pricing, and guaranteed readiness.

Book a Discovery Call →

// COMPREHENSIVE COMPLIANCE ANALYSIS

Long-form sections

Repeating text-section block.

§ 1 How we prioritise: POA&M rules and SPRS weights

Ensuring full compliance with how we prioritise: poa&m rules and sprs weights requires a meticulous, defensible methodology grounded in NIST SP 800-171A. Defense contractors frequently encounter severe delays when assuming standard commercial IT practices satisfy Department of War cybersecurity criteria.

Our Registered Practitioners examine every requirement through the lens of a certified C3PAO auditor. We establish clear asset classifications—separating CUI assets, Security Protection Assets (SPAs), Contractor Risk Managed Assets (CRMAs), and Specialized Assets—to ensure your scope remains defensible without placing unnecessary financial burden on your organization.

§ 2 Working with your MSP

Ensuring full compliance with working with your msp requires a meticulous, defensible methodology grounded in NIST SP 800-171A. Defense contractors frequently encounter severe delays when assuming standard commercial IT practices satisfy Department of War cybersecurity criteria.

Our Registered Practitioners examine every requirement through the lens of a certified C3PAO auditor. We establish clear asset classifications—separating CUI assets, Security Protection Assets (SPAs), Contractor Risk Managed Assets (CRMAs), and Specialized Assets—to ensure your scope remains defensible without placing unnecessary financial burden on your organization.

§ 3 Proving each fix

Ensuring full compliance with proving each fix requires a meticulous, defensible methodology grounded in NIST SP 800-171A. Defense contractors frequently encounter severe delays when assuming standard commercial IT practices satisfy Department of War cybersecurity criteria.

Our Registered Practitioners examine every requirement through the lens of a certified C3PAO auditor. We establish clear asset classifications—separating CUI assets, Security Protection Assets (SPAs), Contractor Risk Managed Assets (CRMAs), and Specialized Assets—to ensure your scope remains defensible without placing unnecessary financial burden on your organization.

§ 4 A typical remediation order

Ensuring full compliance with a typical remediation order requires a meticulous, defensible methodology grounded in NIST SP 800-171A. Defense contractors frequently encounter severe delays when assuming standard commercial IT practices satisfy Department of War cybersecurity criteria.

Our Registered Practitioners examine every requirement through the lens of a certified C3PAO auditor. We establish clear asset classifications—separating CUI assets, Security Protection Assets (SPAs), Contractor Risk Managed Assets (CRMAs), and Specialized Assets—to ensure your scope remains defensible without placing unnecessary financial burden on your organization.

§ 5 After remediation

Ensuring full compliance with after remediation requires a meticulous, defensible methodology grounded in NIST SP 800-171A. Defense contractors frequently encounter severe delays when assuming standard commercial IT practices satisfy Department of War cybersecurity criteria.

Our Registered Practitioners examine every requirement through the lens of a certified C3PAO auditor. We establish clear asset classifications—separating CUI assets, Security Protection Assets (SPAs), Contractor Risk Managed Assets (CRMAs), and Specialized Assets—to ensure your scope remains defensible without placing unnecessary financial burden on your organization.

// FREQUENTLY ASKED QUESTIONS

Common questions

Still have questions regarding your specific CMMC clauses or audit dates? Speak directly with our lead Registered Practitioner.

Book a Discovery Call →

Who makes the changes, you or us? ×

Our Cyber AB Registered Practitioners conduct in-depth scoping and compliance reviews to guarantee defensible alignment with Department of War standards.

In what order should we fix our gaps? +

Do you provide logging, monitoring or incident-response tools? +

What are the best CMMC implementation services for CUI? +

How long does remediation take? +

// KNOWLEDGE ECOSYSTEM

Related pages

Explore related compliance frameworks, staging guides, and scoping resources.

- GUIDE → **CMMC Complete Guide** Everything defense contractors need to know about levels, rulemaking, and audits.
- GUIDE → **CMMC Level 2 Guide** 110 requirements across 14 families: technical details and self vs C3PAO rules.
- GUIDE → **NIST SP 800-171 Explained** The technical foundation of CMMC Level 2 and DFARS 7012 requirements.
- GUIDE → **CMMC Enclave Advisory** How shrinking your CUI scope saves months of time and tens of thousands in audit costs.

Planning to get started on CMMC?

Talk with an accredited Cyber AB Registered Provider Organization.
Get an actionable first step in writing within 30 minutes.

Book a Discovery Call → Call (323) 410-5941

// PART OF CMMC COMPLIANCE · SSP, POA&M AND POLICIES

SSP and POA&M development for CMMC and NIST 800-171

Your System Security Plan, POA&M and policies, written with your team and reviewed against what assessors check. Yes, you need both documents.

Book a Discovery Call → What goes in each document ↓

// DIRECT ADVISORY

Here is exactly what you receive on your confidential 30-minute scoping review:

- ✓ Where you stand today against NIST 800-171
- ✓ Which level and scoping boundary fits your contracts
- ✓ A concrete, written first step before committing budget

Book Discovery Call →

STAGE Documentation Part of CMMC compliance services →

YOU'RE AT THIS STAGE IF… Your SSP, POA&M or policies are missing, copied from a template, or out of date. See the full CMMC 8-step process →

What goes in each document

System Security Plan (SSP)

Accredited advisory guidance and deliverable frameworks.

Explore Resource →

POA&M

Accredited advisory guidance and deliverable frameworks.

Explore Resource →

Policies and procedures

Accredited advisory guidance and deliverable frameworks.

Explore Resource →

// FREE DOWNLOADABLE RESOURCE

SSP Outline Template

- ✓ Line-by-line audit objective breakdown with defense-industry scoring weights
- ✓ Assessor evidence artifact templates and dual-source verification matrix
- ✓ Automated SPRS deduction formulas and deficiency priority flags
- ✓ Executive ownership tracker with target closeout dates for internal teams

PDF / EXCEL WORKBOOK
SSP Outline Template

Enter corporate email address

Instant Free Download →

Strictly confidential. No spam guarantee.

// DETAILED REVIEW STAGES

Templates plus expert review

4 vertical steps; columns: step · who (your team drafts / we review / you approve) · output.

#	REVIEW ACTIVITY	WHO IS INVOLVED	WHAT YOU LEAVE WITH
01	**System Identification**	Secure-Centric + System Admins	**Comprehensive Hardware & Software Inventory**
02	**Control Implementation Statements**	Secure-Centric RPs	**110 Detailed Narratives Matching NIST 800-171A**
03	**Network & Data-Flow Diagrams**	Secure-Centric Technical Architect	**CUI Flow Diagrams & Boundary Topology**
04	**POA&M Milestones Formulation**	Secure-Centric + Leadership	**Defensible Milestones with Resource Allocations**

A sample SSP outline

SSP SECTION	WHAT GOES IN IT		
System Security Plan (SSP)	Complete description of boundary and 110 controls	Annual or when major changes occur	Must describe operational reality with zero fluff
Plan of Action & Milestones (POA&M)	List of temporary control deficiencies and fix dates	Monthly tracking until closeout	Only 1-point and select 3-point controls allowed
Operational Policies (14 Families)	Mandatory governance SOPs for all security domains	Annual review and approval	Assessor verifies staff actively follow each policy
Network Architecture Diagrams	Visual topology of CUI boundary and segmentation	Whenever infrastructure updates	Assessor traces data paths from entry to storage

// COMPREHENSIVE COMPLIANCE ANALYSIS

Long-form sections

Repeating text-section block.

§ 1 POA&M: what can and cannot go on it

Ensuring full compliance with poa&m: what can and cannot go on it requires a meticulous, defensible methodology grounded in NIST SP 800-171A. Defense contractors frequently encounter severe delays when assuming standard commercial IT practices satisfy Department of War cybersecurity criteria.

Our Registered Practitioners examine every requirement through the lens of a certified C3PAO auditor. We establish clear asset classifications—separating CUI assets, Security Protection Assets (SPAs), Contractor Risk Managed Assets (CRMAs), and Specialized Assets—to ensure your scope remains defensible without placing unnecessary financial burden on your organization.

§ 2 Common SSP mistakes

Ensuring full compliance with common ssp mistakes requires a meticulous, defensible methodology grounded in NIST SP 800-171A. Defense contractors frequently encounter severe delays when assuming standard commercial IT practices satisfy Department of War cybersecurity criteria.

Our Registered Practitioners examine every requirement through the lens of a certified C3PAO auditor. We establish clear asset classifications—separating CUI assets, Security Protection Assets (SPAs), Contractor Risk Managed Assets (CRMAs), and Specialized Assets—to ensure your scope remains defensible without placing unnecessary financial burden on your organization.

§ 3 Keeping your SSP current

Ensuring full compliance with keeping your ssp current requires a meticulous, defensible methodology grounded in NIST SP 800-171A. Defense contractors frequently encounter severe delays when assuming standard commercial IT practices satisfy Department of War cybersecurity criteria.

Our Registered Practitioners examine every requirement through the lens of a certified C3PAO auditor. We establish clear asset classifications—separating CUI assets, Security Protection Assets (SPAs), Contractor Risk Managed Assets (CRMAs), and Specialized Assets—to ensure your scope remains defensible without placing unnecessary financial burden on your organization.

§ 4 Diagrams and inventories assessors expect

Ensuring full compliance with diagrams and inventories assessors expect requires a meticulous, defensible methodology grounded in NIST SP 800-171A. Defense contractors frequently encounter severe delays when assuming standard commercial IT practices satisfy Department of War cybersecurity criteria.

Our Registered Practitioners examine every requirement through the lens of a certified C3PAO auditor. We establish clear asset classifications—separating CUI assets, Security Protection Assets (SPAs), Contractor Risk Managed Assets (CRMAs), and Specialized Assets—to ensure your scope remains defensible without placing unnecessary financial burden on your organization.

// FREQUENTLY ASKED QUESTIONS

Common questions

Still have questions regarding your specific CMMC clauses or audit dates? Speak directly with our lead Registered Practitioner.

Book a Discovery Call →

What is a system security plan (SSP) for CMMC? ×

Our Cyber AB Registered Practitioners conduct in-depth scoping and compliance reviews to guarantee defensible alignment with Department of War standards.

What is a POA&M, and what can go on it? +

What document defines the scope of a CMMC assessment? +

Is there a free SSP or POA&M template? +

Who writes the SSP, you or us? +

Can you develop CMMC policies and procedures? +

// KNOWLEDGE ECOSYSTEM

Related pages

Explore related compliance frameworks, staging guides, and scoping resources.

GUIDE →
CMMC Complete Guide
Everything defense contractors need to know about levels, rulemaking, and audits.

GUIDE →
CMMC Level 2 Guide
110 requirements across 14 families: technical details and self vs C3PAO rules.

GUIDE →
NIST SP 800-171 Explained
The technical foundation of CMMC Level 2 and DFARS 7012 requirements.

GUIDE →
CMMC Enclave Advisory
How shrinking your CUI scope saves months of time and tens of thousands in audit costs.

Planning to get started on CMMC?

Talk with an accredited Cyber AB Registered Provider Organization.
Get an actionable first step in writing within 30 minutes.

Book a Discovery Call → Call (323) 410-5941

// PART OF CMMC COMPLIANCE · VIRTUAL CISO

Virtual CISO (vCISO) services for defense contractors

Part-time security leadership that owns your CMMC program: scores, evidence, training and the annual affirmation, without a full-time hire.

Book a Discovery Call → Is a vCISO right for you? ↓

// DIRECT ADVISORY

Here is exactly what you receive on your confidential 30-minute scoping review:

- ✓ Where you stand today against NIST 800-171
- ✓ Which level and scoping boundary fits your contracts
- ✓ A concrete, written first step before committing budget

Book Discovery Call →

STAGE Maintain Part of CMMC compliance services →

YOU'RE AT THIS STAGE IF… You reached your level and now have to keep it: annual affirmation, system changes, fresh evidence. See the full CMMC 8-step process →

// SECTION EXPLAINER

What is a virtual CISO, and when does a company need one?

CMMC (Cybersecurity Maturity Model Certification) is the Department of War standard ensuring defense subcontractors safeguard Federal Contract Information (FCI) and Controlled Unclassified Information (CUI).

Under 32 CFR Part 170 and DFARS 252.204-7021, all contractors handling CUI must achieve Level 2 compliance against the 110 requirements of NIST SP 800-171 Rev 2 before contract award.

What virtual CISO services actually include

Executive Governance & Strategy

Direct board-level cybersecurity reporting, risk management oversight, and compliance budget planning.

Explore Resource →

Audit Liaison & C3PAO Defense

Act as your primary technical spokesperson and defense lead during DIBCAC or C3PAO assessments.

Explore Resource →

Continuous Vulnerability Oversight

Oversee vulnerability scanning, patch management, access reviews, and boundary integrity checks.

Explore Resource →

Annual Affirmation Support

Prepare and defend the annual executive compliance reaffirmation required in the Supplier Performance Risk System.

Explore Resource →

// ENGAGEMENT WORKFLOW

How ongoing support works inside your engagement

Replaces "Two clear ways to engage" (plan cards would sell the vCISO on its own). 3 steps: after the assessment · monthly upkeep · annual affirmation.

01

Post-Assessment Continuity

Maintain assessor-approved controls and manage operational changes without compliance drift.

02

Monthly Upkeep & Monitoring

Ongoing vulnerability management, log review oversight, access audits, and vendor reviews.

03

Annual Affirmation Defense

Conduct yearly senior official affirmation review required under DFARS 252.204-7021.

// FREE DOWNLOADABLE RESOURCE

vCISO Scope Checklist

- ✓ Line-by-line audit objective breakdown with defense-industry scoring weights
- ✓ Assessor evidence artifact templates and dual-source verification matrix
- ✓ Automated SPRS deduction formulas and deficiency priority flags
- ✓ Executive ownership tracker with target closeout dates for internal teams

PDF / EXCEL WORKBOOK
vCISO Scope Checklist

Enter corporate email address

Instant Free Download →

Strictly confidential. No spam guarantee.

// COMPREHENSIVE COMPLIANCE ANALYSIS

Long-form sections

Repeating text-section block.

§ 1 Where vCISO services land hardest

Ensuring full compliance with where vciso services land hardest requires a meticulous, defensible methodology grounded in NIST SP 800-171A. Defense contractors frequently encounter severe delays when assuming standard commercial IT practices satisfy Department of War cybersecurity criteria.

Our Registered Practitioners examine every requirement through the lens of a certified C3PAO auditor. We establish clear asset classifications—separating CUI assets, Security Protection Assets (SPAs), Contractor Risk Managed Assets (CRMAs), and Specialized Assets—to ensure your scope remains defensible without placing unnecessary financial burden on your organization.

§ 2 How we run a vCISO engagement

Ensuring full compliance with how we run a vciso engagement requires a meticulous, defensible methodology grounded in NIST SP 800-171A. Defense contractors frequently encounter severe delays when assuming standard commercial IT practices satisfy Department of War cybersecurity criteria.

Our Registered Practitioners examine every requirement through the lens of a certified C3PAO auditor. We establish clear asset classifications—separating CUI assets, Security Protection Assets (SPAs), Contractor Risk Managed Assets (CRMAs), and Specialized Assets—to ensure your scope remains defensible without placing unnecessary financial burden on your organization.

§ 3 What a typical month looks like

Ensuring full compliance with what a typical month looks like requires a meticulous, defensible methodology grounded in NIST SP 800-171A. Defense contractors frequently encounter severe delays when assuming standard commercial IT practices satisfy Department of War cybersecurity criteria.

Our Registered Practitioners examine every requirement through the lens of a certified C3PAO auditor. We establish clear asset classifications—separating CUI assets, Security Protection Assets (SPAs), Contractor Risk Managed Assets (CRMAs), and Specialized Assets—to ensure your scope remains defensible without placing unnecessary financial burden on your organization.

§ 4 What a vCISO does not do

Ensuring full compliance with what a vciso does not do requires a meticulous, defensible methodology grounded in NIST SP 800-171A. Defense contractors frequently encounter severe delays when assuming standard commercial IT practices satisfy Department of War cybersecurity criteria.

Our Registered Practitioners examine every requirement through the lens of a certified C3PAO auditor. We establish clear asset classifications—separating CUI assets, Security Protection Assets (SPAs), Contractor Risk Managed Assets (CRMAs), and Specialized Assets—to ensure your scope remains defensible without placing unnecessary financial burden on your organization.

§ 5 Your vCISO and the annual affirmation

Ensuring full compliance with your vciso and the annual affirmation requires a meticulous, defensible methodology grounded in NIST SP 800-171A. Defense contractors frequently encounter severe delays when assuming standard commercial IT practices satisfy Department of War cybersecurity criteria.

Our Registered Practitioners examine every requirement through the lens of a certified C3PAO auditor. We establish clear asset classifications—separating CUI assets, Security Protection Assets (SPAs), Contractor Risk Managed Assets (CRMAs), and Specialized Assets—to ensure your scope remains defensible without placing unnecessary financial burden on your organization.

§ 6 How to choose a vCISO

Ensuring full compliance with how to choose a vciso requires a meticulous, defensible methodology grounded in NIST SP 800-171A. Defense contractors frequently encounter severe delays when assuming standard commercial IT practices satisfy Department of War cybersecurity criteria.

Our Registered Practitioners examine every requirement through the lens of a certified C3PAO auditor. We establish clear asset classifications—separating CUI assets, Security Protection Assets (SPAs), Contractor Risk Managed Assets (CRMAs), and Specialized Assets—to ensure your scope remains defensible without placing unnecessary financial burden on your organization.

// FREQUENTLY ASKED QUESTIONS

Common questions

Still have questions regarding your specific CMMC clauses or audit dates? Speak directly with our lead Registered Practitioner.

Book a Discovery Call →

What is a virtual CISO (vCISO)? ×

Our Cyber AB Registered Practitioners conduct in-depth scoping and compliance reviews to guarantee defensible alignment with Department of War standards.

vCISO vs full-time CISO vs managed service: which fits a growing contractor? +

Does a vCISO help with CMMC? +

Can a vCISO keep us compliant all year? +

What does a vCISO not do? +

Who is a vCISO right for? +

// KNOWLEDGE ECOSYSTEM

Related pages

Explore related compliance frameworks, staging guides, and scoping resources.

GUIDE →
CMMC Complete Guide
Everything defense contractors need to know about levels, rulemaking, and audits.

GUIDE →
CMMC Level 2 Guide
110 requirements across 14 families: technical details and self vs C3PAO rules.

GUIDE →
NIST SP 800-171 Explained
The technical foundation of CMMC Level 2 and DFARS 7012 requirements.

GUIDE →
CMMC Enclave Advisory
How shrinking your CUI scope saves months of time and tens of thousands in audit costs.

Planning to get started on CMMC?

Talk with an accredited Cyber AB Registered Provider Organization.
Get an actionable first step in writing within 30 minutes.

Book a Discovery Call → Call (323) 410-5941

// THE COMPLETE GUIDE

CMMC (Cybersecurity Maturity Model Certification): the complete guide

DIRECT ANSWER (EXECUTIVE SUMMARY)

CMMC is the Department of War program that checks defense contractors protect FCI and CUI. It has three levels, set by your contract.

Reviewed by: Son Phan, Principal Architect · Last Updated: Q4 2026 ·

Cyber AB RPO Verified

// INTERACTIVE TOOL

Does your contract contain DFARS 7012? ☑
Do you store or process technical drawings / CAD? ☑
Are you a designated critical weapon system supplier? ☐

Calculated Level Requirement:
CMMC Level 2 (110 Controls)

View Level 2 Action Plan →

Cyber AB Registered Provider Organization · CPN #3942 Formally Reviewed: November 2026 · 32 CFR 170 Compliant

ON THIS PAGE Jump to section:
Scoping & Boundaries ↓
The 14 Control Families ↓
SPRS Scoring Methodology ↓
Technical Remediation & Enclaves ↓
SSP & Policy Documentation ↓
C3PAO Audit Day Readiness ↓

// SECTION EXPLAINER

Introduction to the CMMC guide

CMMC (Cybersecurity Maturity Model Certification) is the Department of War standard ensuring defense subcontractors safeguard Federal Contract Information (FCI) and Controlled Unclassified Information (CUI).

Under 32 CFR Part 170 and DFARS 252.204-7021, all contractors handling CUI must achieve Level 2 compliance against the 110 requirements of NIST SP 800-171 Rev 2 before contract award.

Our Cyber AB Registered Practitioners conduct on-site facility walkthroughs, map exact CUI boundaries, guide technical remediation, and co-author your assessor-ready System Security Plan (SSP).

// CORE PRINCIPLES & INDICATORS

The ultimate guide to mastering your CMMC compliance

What this guide covers: list of points (each links down the page).

- ✓ **Targeted Gap Identification** Audit Day verification ensuring every safeguard is operational and backed by dual evidence artifacts.
- ✓ **Scope Isolation & Segmentation** Segregating CUI networks and servers to drastically minimize assessment boundary costs.
- ✓ **Full Regulatory Defensibility** Policies, procedures, and implementation notes mapped directly to NIST SP 800-171A objectives.
- ✓ **Continuous Compliance Management** Ongoing support to maintain audit readiness between triennial C3PAO evaluation cycles.

// SECTION EXPLAINER

Why CMMC matters and who must comply

CMMC (Cybersecurity Maturity Model Certification) is the Department of War standard ensuring defense subcontractors safeguard Federal Contract Information (FCI) and Controlled Unclassified Information (CUI).

Under 32 CFR Part 170 and DFARS 252.204-7021, all contractors handling CUI must achieve Level 2 compliance against the 110 requirements of NIST SP 800-171 Rev 2 before contract award.

Our Cyber AB Registered Practitioners conduct on-site facility walkthroughs, map exact CUI boundaries, guide technical remediation, and co-author your assessor-ready System Security Plan (SSP).

CMMC levels compared

	LEVEL 1	LEVEL 2	LEVEL 3
Target Information Safeguarded	Federal Contract Information (FCI)	Controlled Unclassified Information (CUI)	High-Value Assets & Critical CUI
Security Controls Baseline	15 FAR 52.204-21 Basic Safeguards	110 NIST SP 800-171 Requirements	110 NIST SP 800-171 + Select 800-172 Controls
Assessment & Audit Mechanism	Annual Self-Assessment in SPRS	Triennial Independent C3PAO Audit	Triennial Government-Led (DIBCAC) Audit
Executive Affirmation	Annual Affirmation by Corporate Official	Annual Executive Affirmation in SPRS	Annual Executive Affirmation in SPRS
Defense Supply Chain Tier	Subcontractors handling FCI only	Prime & Subcontractors handling DoD CUI	Defense Prime Contractors on critical programs
Typical Implementation Timeline	1 – 2 months	6 – 9 months	9 – 14 months

// SECTION EXPLAINER

CMMC requirements and frameworks

CMMC (Cybersecurity Maturity Model Certification) is the Department of War standard ensuring defense subcontractors safeguard Federal Contract Information (FCI) and Controlled Unclassified Information (CUI).

Under 32 CFR Part 170 and DFARS 252.204-7021, all contractors handling CUI must achieve Level 2 compliance against the 110 requirements of NIST SP 800-171 Rev 2 before contract award.

Our Cyber AB Registered Practitioners conduct on-site facility walkthroughs, map exact CUI boundaries, guide technical remediation, and co-author your assessor-ready System Security Plan (SSP).

// ENGAGEMENT WORKFLOW

CMMC phases

A few numbered steps with dated status ("on hold" where suspended).

01
Phase 1: Rulemaking
Final 32 CFR 170 published; 48 CFR acquisition rulemaking active in DFARS solicitations.

02
Phase 2: Self-Assessments
Level 1 and Level 2 self-assessments with executive affirmation required in DoD contracts.

03
Phase 3: C3PAO Certifications
Official third-party certifications phased into prioritized prime and tier-1 subcontracts.

04
Phase 4: Full Enforcement
Complete condition of contract award across all DoD solicitations handling FCI or CUI.

// FREE DOWNLOADABLE RESOURCE

CMMC Quick-Start Guide (one page)

- ✓ Line-by-line audit objective breakdown with defense-industry scoring weights
- ✓ Assessor evidence artifact templates and dual-source verification matrix
- ✓ Automated SPRS deduction formulas and deficiency priority flags
- ✓ Executive ownership tracker with target closeout dates for internal teams

PDF / EXCEL WORKBOOK
CMMC Quick-Start Guide (one page)

Enter corporate email address
Instant Free Download →
Strictly confidential. No spam guarantee.

// COMPREHENSIVE COMPLIANCE ANALYSIS

Long-form sections

Repeating text-section block.

§ 1 The CMMC ecosystem

Ensuring full compliance with the cmmc ecosystem requires a meticulous, defensible methodology grounded in NIST SP 800-171A. Defense contractors frequently encounter severe delays when assuming standard commercial IT practices satisfy Department of War cybersecurity criteria.

Our Registered Practitioners examine every requirement through the lens of a certified C3PAO auditor. We establish clear asset classifications—separating CUI assets, Security Protection Assets (SPAs), Contractor Risk Managed Assets (CRMAs), and Specialized Assets—to ensure your scope remains defensible without placing unnecessary financial burden on your organization.

§ 2 CMMC 1.0 versus CMMC 2.0

Ensuring full compliance with cmmc 1.0 versus cmmc 2.0 requires a meticulous, defensible methodology grounded in NIST SP 800-171A. Defense contractors frequently encounter severe delays when assuming standard commercial IT practices satisfy Department of War cybersecurity criteria.

Our Registered Practitioners examine every requirement through the lens of a certified C3PAO auditor. We establish clear asset classifications—separating CUI assets, Security Protection Assets (SPAs), Contractor Risk Managed Assets (CRMAs), and Specialized Assets—to ensure your scope remains defensible without placing unnecessary financial burden on your organization.

§ 3 What drives the cost of CMMC

Ensuring full compliance with what drives the cost of cmmc requires a meticulous, defensible methodology grounded in NIST SP 800-171A. Defense contractors frequently encounter severe delays when assuming standard commercial IT practices satisfy Department of War cybersecurity criteria.

Our Registered Practitioners examine every requirement through the lens of a certified C3PAO auditor. We establish clear asset classifications—separating CUI assets, Security Protection Assets (SPAs), Contractor Risk Managed Assets (CRMAs), and Specialized Assets—to ensure your scope remains defensible without placing unnecessary financial burden on your organization.

§ 4 Common CMMC myths

Ensuring full compliance with common cmmc myths requires a meticulous, defensible methodology grounded in NIST SP 800-171A. Defense contractors frequently encounter severe delays when assuming standard commercial IT practices satisfy Department of War cybersecurity criteria.

Our Registered Practitioners examine every requirement through the lens of a certified C3PAO auditor. We establish clear asset classifications—separating CUI assets, Security Protection Assets (SPAs), Contractor Risk Managed Assets (CRMAs), and Specialized Assets—to ensure your scope remains defensible without placing unnecessary financial burden on your organization.

§ 5 Your first five actions

Ensuring full compliance with your first five actions requires a meticulous, defensible methodology grounded in NIST SP 800-171A. Defense contractors frequently encounter severe delays when assuming standard commercial IT practices satisfy Department of War cybersecurity criteria.

Our Registered Practitioners examine every requirement through the lens of a certified C3PAO auditor. We establish clear asset classifications—separating CUI assets, Security Protection Assets (SPAs), Contractor Risk Managed Assets (CRMAs), and Specialized Assets—to ensure your scope remains defensible without placing unnecessary financial burden on your organization.

§ 6 Level 3 in brief

Ensuring full compliance with level 3 in brief requires a meticulous, defensible methodology grounded in NIST SP 800-171A. Defense contractors frequently encounter severe delays when assuming standard commercial IT practices satisfy Department of War cybersecurity criteria.

Our Registered Practitioners examine every requirement through the lens of a certified C3PAO auditor. We establish clear asset classifications—separating CUI assets, Security Protection Assets (SPAs), Contractor Risk Managed Assets (CRMAs), and Specialized Assets—to ensure your scope remains defensible without placing unnecessary financial burden on your organization.

§ 7 CMMC after you pass

Ensuring full compliance with cmmc after you pass requires a meticulous, defensible methodology grounded in NIST SP 800-171A. Defense contractors frequently encounter severe delays when assuming standard commercial IT practices satisfy Department of War cybersecurity criteria.

Our Registered Practitioners examine every requirement through the lens of a certified C3PAO auditor. We establish clear asset classifications—separating CUI assets, Security Protection Assets (SPAs), Contractor Risk Managed Assets (CRMAs), and Specialized Assets—to ensure your scope remains defensible without placing unnecessary financial burden on your organization.

// VERIFIED DEFENSE METRICS

CMMC in four numbers

CMMC compliance numbers grounded in Department of War regulatory criteria.

110	320	100%	120+
NIST SP 800-171 Controls	**Assessment Objectives**	**C3PAO Pass Guarantee**	**Defense Contractors**
Rev 2 security requirements across 14 families required for CMMC Level 2 certification.	Specific testing criteria defined in NIST SP 800-171A that assessors examine and verify.	Every contractor we prepare passes their official Level 2 audit without major non-conformities.	Subcontractors and suppliers guided across 45 states protecting $2.4B in DoD contracts.

// TOPIC CLUSTER

Go deeper: the pages around this guide

Cross-linked compliance pillars, assessment staging, and implementation guides.

CMMC Compliance Services →
CMMC Readiness Assessment →
CMMC Gap & Mock Assessment →
NIST SP 800-171 Services →
CMMC Remediation Advisory →
SSP & POA&M Development →
Virtual CISO (vCISO) →
CMMC Enclave Advisory →
The CMMC 8-Step Process →

// REGULATORY CITATIONS

Active 32 CFR 170 Rule

What changed in this guide + primary sources

Last formally reviewed and verified against DoD acquisition rulemaking: **November 2026**.

Source	Link
Department of War CIO: CMMC Official Portal	View Official Government Source ↗
Federal Register: 32 CFR Part 170 (CMMC Program Final Rule)	View Official Government Source ↗
NIST SP 800-171 Rev 2: Protecting CUI in Nonfederal Systems	View Official Government Source ↗
The Cyber AB Official Marketplace (RPO #3942)	View Official Government Source ↗

// FREQUENTLY ASKED QUESTIONS

Common questions

Still have questions regarding your specific CMMC clauses or audit dates? Speak directly with our lead Registered Practitioner.

Book a Discovery Call →

What does CMMC stand for? ×

Our Cyber AB Registered Practitioners conduct in-depth scoping and compliance reviews to guarantee defensible alignment with Department of War standards.

Who needs CMMC? +

Which CMMC level do I need? +

When is CMMC required? +

What is the difference between CMMC 1.0 and CMMC 2.0? +

Does Level 1 need a third-party audit, and how do I get Level 1? +

Which DFARS clause makes CMMC a contract requirement? +

What are the CMMC compliance requirements for defense contractors? +

Who can assess Level 3? +

// KNOWLEDGE ECOSYSTEM

Related pages

Explore related compliance frameworks, staging guides, and scoping resources.

GUIDE →
CMMC Complete Guide
Everything defense contractors need to know about levels, rulemaking, and audits.

GUIDE →
CMMC Level 2 Guide
110 requirements across 14 families: technical details and self vs C3PAO rules.

GUIDE →
NIST SP 800-171 Explained
The technical foundation of CMMC Level 2 and DFARS 7012 requirements.

GUIDE →
CMMC Enclave Advisory
How shrinking your CUI scope saves months of time and tens of thousands in audit costs.

Planning to get started on CMMC?

Talk with an accredited Cyber AB Registered Provider Organization.
Get an actionable first step in writing within 30 minutes.

Book a Discovery Call → Call (323) 410-5941

// LEVEL 2 GUIDE

CMMC Level 2: requirements, assessment and what to do first

DIRECT ANSWER (EXECUTIVE SUMMARY)

110 requirements from NIST SP 800-171, checked by a self-assessment or an authorized C3PAO every three years, with an annual affirmation.

// KEY SPECIFICATIONS

- ✓ 110 requirements
- ✓ 14 families
- ✓ 3-year cycle

Reviewed by: **Son Phan, Principal Architect** • Last Updated: **Q4 2026** •

Cyber AB RPO Verified

// SECTION EXPLAINER

CMMC Level 2 in brief

CMMC (Cybersecurity Maturity Model Certification) is the Department of War standard ensuring defense subcontractors safeguard Federal Contract Information (FCI) and Controlled Unclassified Information (CUI).

Under 32 CFR Part 170 and DFARS 252.204-7021, all contractors handling CUI must achieve Level 2 compliance against the 110 requirements of NIST SP 800-171 Rev 2 before contract award.

ON THIS PAGE Jump to section:

Scoping & Boundaries ↓
The 14 Control Families ↓
SPRS Scoring Methodology ↓
Technical Remediation & Enclaves ↓
SSP & Policy Documentation ↓
C3PAO Audit Day Readiness ↓

// CORE PRINCIPLES & INDICATORS

What CMMC Level 2 requires

List of 5 points.

- ✓ **110 NIST SP 800-171 Requirements** Rigorous operational implementation across all 14 security families, fulfilling all 320 assessment objectives in NIST SP 800-171A.
- ✓ **Triennial Independent C3PAO Audit** Formal on-site and remote evaluation conducted by an Authorized Third-Party Assessment Organization accredited by the Cyber AB.
- ✓ **Assessor-Ready System Security Plan** Detailed, defensible documentation detailing how every technical and physical safeguard operates inside your CUI boundary.
- ✓ **Strict Time-Bound POA&M Rules** Plan of Action allowed only for eligible 1-point controls; high-weight (-5 and -3) controls must be 100% remediated prior to audit.
- ✓ **Annual Executive SPRS Affirmation** Corporate executive must formally sign and submit an annual affirmation of continuing cybersecurity compliance.

// 110 NIST CONTROLS

The 110 requirements (14 families)

Click on any control family below to see requirement counts and scope objectives tested by C3PAO assessors.

Code	Controls	Family	Description
AC	22 Controls	Access Control	Limit information system access to authorized users and devices.
AT	3 Controls	Awareness & Training	Ensure personnel understand cybersecurity risks and CUI safeguarding duties.
AU	9 Controls	Audit & Accountability	Track, record, review, and correlate security actions and logs.
CM	9 Controls	Configuration Management	Establish and maintain baseline configurations and hardware inventories.
IA	11 Controls	Identification & Authentication	Enforce MFA, user identity proofs, and cryptographic credentials.
IR	3 Controls	Incident Response	Detect, analyze, contain, and report cyber incidents to DoD within 72 hours.
MA	6 Controls	Maintenance	Perform scheduled system maintenance with authenticated tools.
MP	8 Controls	Media Protection	Sanitize, mark, and securely transport physical and digital CUI media.
PE	6 Controls	Physical Protection	Escort visitors, protect server rooms, and enforce physical locks.
PS	2 Controls	Personnel Security	Screen individuals before authorizing access to CUI systems.
RA	3 Controls	Risk Assessment	Identify vulnerabilities and perform vulnerability scanning.
CA	4 Controls	Security Assessment	Regularly test controls, maintain SSP, and manage the POA&M.
SC	16 Controls	System & Communications	Enforce network boundary firewalls, FIPS 140-2 encryption, and VPNs.
SI	7 Controls	System & Information Integrity	Deploy antivirus, spam protection, and continuous system monitoring.

// SECTION EXPLAINER

Who needs Level 2

CMMC (Cybersecurity Maturity Model Certification) is the Department of War standard ensuring defense subcontractors safeguard Federal Contract Information (FCI) and Controlled Unclassified Information (CUI).

Under 32 CFR Part 170 and DFARS 252.204-7021, all contractors handling CUI must achieve Level 2 compliance against the 110 requirements of NIST SP 800-171 Rev 2 before contract award.

Our Cyber AB Registered Practitioners conduct on-site facility walkthroughs, map exact CUI boundaries, guide technical remediation, and co-author your assessor-ready System Security Plan (SSP).

// SECTION EXPLAINER

CMMC Level 2 compliance requirements

CMMC (Cybersecurity Maturity Model Certification) is the Department of War standard ensuring defense subcontractors safeguard Federal Contract Information (FCI) and Controlled Unclassified Information (CUI).

Under 32 CFR Part 170 and DFARS 252.204-7021, all contractors handling CUI must achieve Level 2 compliance against the 110 requirements of NIST SP 800-171 Rev 2 before contract award.

Our Cyber AB Registered Practitioners conduct on-site facility walkthroughs, map exact CUI boundaries, guide technical remediation, and co-author your assessor-ready System Security Plan (SSP).

// FREE DOWNLOADABLE RESOURCE

110-Control Checklist (NIST 800-171 / CMMC Level 2)

- ✓ Line-by-line audit objective breakdown with defense-industry scoring weights
- ✓ Assessor evidence artifact templates and dual-source verification matrix
- ✓ Automated SPRS deduction formulas and deficiency priority flags
- ✓ Executive ownership tracker with target closeout dates for internal teams

PDF / EXCEL WORKBOOK

110-Control Checklist (NIST 800-171 / CMMC Level 2)

Enter corporate email address

Instant Free Download →

Strictly confidential. No spam guarantee.

Self-assessment or C3PAO: which does my contract need?

	SELF-ASSESSMENT	C3PAO ASSESSMENT	
Level 2 Self-Assessment	Contracts with prioritized CUI without critical DoD assets	Internal Team / Guided by RPO	Yes, annual affirmation in SPRS
Level 2 C3PAO Assessment	Contracts with critical national security CUI (triennial)	Authorized independent C3PAO	Yes, official 3-year certification issued

// COMPREHENSIVE COMPLIANCE ANALYSIS

Long-form sections

Repeating text-section block.

§ 1 The 320 assessment objectives, explained

Ensuring full compliance with the 320 assessment objectives, explained requires a meticulous, defensible methodology grounded in NIST SP 800-171A. Defense contractors frequently encounter severe delays when assuming standard commercial IT practices satisfy Department of War cybersecurity criteria.

Our Registered Practitioners examine every requirement through the lens of a certified C3PAO auditor. We establish clear asset classifications—separating CUI assets, Security Protection Assets (SPAs), Contractor Risk Managed Assets (CRMAs), and Specialized Assets—to ensure your scope remains defensible without placing unnecessary financial burden on your organization.

§ 2 Where the effort goes across the 14 families

Ensuring full compliance with where the effort goes across the 14 families requires a meticulous, defensible methodology grounded in NIST SP 800-171A. Defense contractors frequently encounter severe delays when assuming standard commercial IT practices satisfy Department of War cybersecurity criteria.

Our Registered Practitioners examine every requirement through the lens of a certified C3PAO auditor. We establish clear asset classifications—separating CUI assets, Security Protection Assets (SPAs), Contractor Risk Managed Assets (CRMAs), and Specialized Assets—to ensure your scope remains defensible without placing unnecessary financial burden on your organization.

§ 3 Who owns what in a Level 2 program

Ensuring full compliance with who owns what in a level 2 program requires a meticulous, defensible methodology grounded in NIST SP 800-171A. Defense contractors frequently encounter severe delays when assuming standard commercial IT practices satisfy Department of War cybersecurity criteria.

Our Registered Practitioners examine every requirement through the lens of a certified C3PAO auditor. We establish clear asset classifications—separating CUI assets, Security Protection Assets (SPAs), Contractor Risk Managed Assets (CRMAs), and Specialized Assets—to ensure your scope remains defensible without placing unnecessary financial burden on your organization.

§ 4 A 90-day Level 2 starter plan

Ensuring full compliance with a 90-day level 2 starter plan requires a meticulous, defensible methodology grounded in NIST SP 800-171A. Defense contractors frequently encounter severe delays when assuming standard commercial IT practices satisfy Department of War cybersecurity criteria.

Our Registered Practitioners examine every requirement through the lens of a certified C3PAO auditor. We establish clear asset classifications—separating CUI assets, Security Protection Assets (SPAs), Contractor Risk Managed Assets (CRMAs), and Specialized Assets—to ensure your scope remains defensible without placing unnecessary financial burden on your organization.

// VERIFIED DEFENSE METRICS

Level 2 in four numbers

CMMC compliance numbers grounded in Department of War regulatory criteria.

110	320	100%	120+
NIST SP 800-171 Controls	**Assessment Objectives**	**C3PAO Pass Guarantee**	**Defense Contractors**
Rev 2 security requirements across 14 families required for CMMC Level 2 certification.	Specific testing criteria defined in NIST SP 800-171A that assessors examine and verify.	Every contractor we prepare passes their official Level 2 audit without major non-conformities.	Subcontractors and suppliers guided across 45 states protecting $2.4B in DoD contracts.

// TOPIC CLUSTER

Go deeper: the pages around this guide

Cross-linked compliance pillars, assessment staging, and implementation guides.

- CMMC Compliance Services →
- CMMC Readiness Assessment →
- CMMC Gap & Mock Assessment →
- NIST SP 800-171 Services →
- CMMC Remediation Advisory →
- SSP & POA&M Development →
- Virtual CISO (vCISO) →
- CMMC Enclave Advisory →
- The CMMC 8-Step Process →

// REGULATORY CITATIONS

Active 32 CFR 170 Rule

What changed in this guide + primary sources

Last formally reviewed and verified against DoD acquisition rulemaking: **November 2026**.

🏛 Department of War CIO: CMMC Official Portal	View Official Government Source ↗
🏛 Federal Register: 32 CFR Part 170 (CMMC Program Final Rule)	View Official Government Source ↗
🏛 NIST SP 800-171 Rev 2: Protecting CUI in Nonfederal Systems	View Official Government Source ↗
🏛 The Cyber AB Official Marketplace (RPO #3942)	View Official Government Source ↗

// FREQUENTLY ASKED QUESTIONS

Common questions

Still have questions regarding your specific CMMC clauses or audit dates? Speak directly with our lead Registered Practitioner.

Book a Discovery Call →

Is CMMC Level 2 based on NIST SP 800-171? ×

Our Cyber AB Registered Practitioners conduct in-depth scoping and compliance reviews to guarantee defensible alignment with Department of War standards.

How many controls are in CMMC Level 2? +

What are the CMMC Level 2 requirements for small defense contractors? +

Self-assessment or C3PAO: which does my contract need? +

When is Level 2 required? +

What does a C3PAO check at Level 2? +

What is the difference between Level 1 and Level 2? +

// KNOWLEDGE ECOSYSTEM

Related pages

Explore related compliance frameworks, staging guides, and scoping resources.

GUIDE →	GUIDE →	GUIDE →	GUIDE →
CMMC Complete Guide	**CMMC Level 2 Guide**	**NIST SP 800-171 Explained**	**CMMC Enclave Advisory**
Everything defense contractors need to know about levels, rulemaking, and audits.	110 requirements across 14 families: technical details and self vs C3PAO rules.	The technical foundation of CMMC Level 2 and DFARS 7012 requirements.	How shrinking your CUI scope saves months of time and tens of thousands in audit costs.

Planning to get started on CMMC?

Talk with an accredited Cyber AB Registered Provider Organization. Get an actionable first step in writing within 30 minutes.

Book a Discovery Call →   Call (323) 410-5941

// NIST SP 800-171 GUIDE

NIST 800-171 explained: the standard behind CMMC Level 2

DIRECT ANSWER (EXECUTIVE SUMMARY)

NIST SP 800-171 is the 110-requirement standard for protecting CUI in contractor systems. DFARS 7012 requires it; CMMC Level 2 checks it.

Reviewed by: **Son Phan, Principal Architect** • Last Updated: **Q4 2026** •

Cyber AB RPO Verified

// KEY SPECIFICATIONS

✓ NIST SP 800-171 → DFARS 7012 / 7019 / 7020 → CMMC Level 2

// SECTION EXPLAINER

What NIST 800-171 is and who it applies to

CMMC (Cybersecurity Maturity Model Certification) is the Department of War standard ensuring defense subcontractors safeguard Federal Contract Information (FCI) and Controlled Unclassified Information (CUI).

Under 32 CFR Part 170 and DFARS 252.204-7021, all contractors handling CUI must achieve Level 2 compliance against the 110 requirements of NIST SP 800-171 Rev 2 before contract award.

Our Cyber AB Registered Practitioners conduct on-site facility walkthroughs, map exact CUI boundaries, guide technical remediation, and co-author your assessor-ready System Security Plan (SSP).

ON THIS PAGE Jump to section:
Scoping & Boundaries ↓
The 14 Control Families ↓
SPRS Scoring Methodology ↓
Technical Remediation & Enclaves ↓
SSP & Policy Documentation ↓
C3PAO Audit Day Readiness ↓

// 110 CONTROLS IN 14 FAMILIES

The 14 control families

The complete NIST SP 800-171 Rev 2 security control architecture required for CMMC Level 2.

Code	Family	Controls
AC	Access Control	22 Controls
AT	Awareness & Training	3 Controls
AU	Audit & Accountability	9 Controls
CM	Configuration Mgmt	9 Controls
IA	Identification & Auth	11 Controls
IR	Incident Response	3 Controls
MA	Maintenance	6 Controls
MP	Media Protection	8 Controls
PS	Personnel Security	2 Controls
PE	Physical Protection	6 Controls
RA	Risk Assessment	3 Controls
CA	Security Assessment	4 Controls
SC	System & Comms	16 Controls
SI	System & Info Integrity	7 Controls

// SECTION EXPLAINER

DFARS 7012, 7019 and 7020 explained

CMMC (Cybersecurity Maturity Model Certification) is the Department of War standard ensuring defense subcontractors safeguard Federal Contract Information (FCI) and Controlled Unclassified Information (CUI).

Under 32 CFR Part 170 and DFARS 252.204-7021, all contractors handling CUI must achieve Level 2 compliance against the 110 requirements of NIST SP 800-171 Rev 2 before contract award.

Our Cyber AB Registered Practitioners conduct on-site facility walkthroughs, map exact CUI boundaries, guide technical remediation, and co-author your assessor-ready System Security Plan (SSP).

// SECTION EXPLAINER

SPRS score: how it works

CMMC (Cybersecurity Maturity Model Certification) is the Department of War standard ensuring defense subcontractors safeguard Federal Contract Information (FCI) and Controlled Unclassified Information (CUI).

Under 32 CFR Part 170 and DFARS 252.204-7021, all contractors handling CUI must achieve Level 2 compliance against the 110 requirements of NIST SP 800-171 Rev 2 before contract award.

Our Cyber AB Registered Practitioners conduct on-site facility walkthroughs, map exact CUI boundaries, guide technical remediation, and co-author your assessor-ready System Security Plan (SSP).

// SECTION EXPLAINER

SSP and POA&M basics

CMMC (Cybersecurity Maturity Model Certification) is the Department of War standard ensuring defense subcontractors safeguard Federal Contract Information (FCI) and Controlled Unclassified Information (CUI).

Under 32 CFR Part 170 and DFARS 252.204-7021, all contractors handling CUI must achieve Level 2 compliance against the 110 requirements of NIST SP 800-171 Rev 2 before contract award.

Our Cyber AB Registered Practitioners conduct on-site facility walkthroughs, map exact CUI boundaries, guide technical remediation, and co-author your assessor-ready System Security Plan (SSP).

// FREE DOWNLOADABLE RESOURCE

NIST SP 800-171 Self-Assessment Scoring Sheet

- ✓ Line-by-line audit objective breakdown with defense-industry scoring weights
- ✓ Assessor evidence artifact templates and dual-source verification matrix
- ✓ Automated SPRS deduction formulas and deficiency priority flags
- ✓ Executive ownership tracker with target closeout dates for internal teams

PDF / EXCEL WORKBOOK
NIST SP 800-171 Self-Assessment Scoring Sheet

Enter corporate email address

Instant Free Download →

Strictly confidential. No spam guarantee.

Rev 2 or Rev 3: which one applies to my contract?

	REV 2	REV 3	
Status in Rulemaking	Current official standard for CMMC Level 2	Published draft / final standard	Rev 2 applies until DFARS 7012 is formally updated
Control Count	110 requirements across 14 families	Expanded control count & tailored families	Contractors must prepare for Rev 2 certification first
SPRS Scoring	Standard -203 to +110 scoring methodology	Updated scoring rubric pending DFARS rule	Active DoD solicitations score against Rev 2 exclusively

// COMPREHENSIVE COMPLIANCE ANALYSIS

Long-form sections

Repeating text-section block.

§ 1 Basic and derived requirements

Ensuring full compliance with basic and derived requirements requires a meticulous, defensible methodology grounded in NIST SP 800-171A. Defense contractors frequently encounter severe delays when assuming standard commercial IT practices satisfy Department of War cybersecurity criteria.

Our Registered Practitioners examine every requirement through the lens of a certified C3PAO auditor. We establish clear asset classifications—separating CUI assets, Security Protection Assets (SPAs), Contractor Risk Managed Assets (CRMAs), and Specialized Assets—to ensure your scope remains defensible without placing unnecessary financial burden on your organization.

§ 2 NIST SP 800-171A: how requirements are assessed

Ensuring full compliance with nist sp 800-171a: how requirements are assessed requires a meticulous, defensible methodology grounded in NIST SP 800-171A. Defense contractors frequently encounter severe delays when assuming standard commercial IT practices satisfy Department of War cybersecurity criteria.

Our Registered Practitioners examine every requirement through the lens of a certified C3PAO auditor. We establish clear asset classifications—separating CUI assets, Security Protection Assets (SPAs), Contractor Risk Managed Assets (CRMAs), and Specialized Assets—to ensure your scope remains defensible without placing unnecessary financial burden on your organization.

§ 3 Common NIST 800-171 gaps

Ensuring full compliance with common nist 800-171 gaps requires a meticulous, defensible methodology grounded in NIST SP 800-171A. Defense contractors frequently encounter severe delays when assuming standard commercial IT practices satisfy Department of War cybersecurity criteria.

Our Registered Practitioners examine every requirement through the lens of a certified C3PAO auditor. We establish clear asset classifications—separating CUI assets, Security Protection Assets (SPAs), Contractor Risk Managed Assets (CRMAs), and Specialized Assets—to ensure your scope remains defensible without placing unnecessary financial burden on your organization.

§ 4 A practical order of work

Ensuring full compliance with a practical order of work requires a meticulous, defensible methodology grounded in NIST SP 800-171A. Defense contractors frequently encounter severe delays when assuming standard commercial IT practices satisfy Department of War cybersecurity criteria.

Our Registered Practitioners examine every requirement through the lens of a certified C3PAO auditor. We establish clear asset classifications—separating CUI assets, Security Protection Assets (SPAs), Contractor Risk Managed Assets (CRMAs), and Specialized Assets—to ensure your scope remains defensible without placing unnecessary financial burden on your organization.

§ 5 Doing an honest self-assessment

Ensuring full compliance with doing an honest self-assessment requires a meticulous, defensible methodology grounded in NIST SP 800-171A. Defense contractors frequently encounter severe delays when assuming standard commercial IT practices satisfy Department of War cybersecurity criteria.

Our Registered Practitioners examine every requirement through the lens of a certified C3PAO auditor. We establish clear asset classifications—separating CUI assets, Security Protection Assets (SPAs), Contractor Risk Managed Assets (CRMAs), and Specialized Assets—to ensure your scope remains defensible without placing unnecessary financial burden on your organization.

§ 6 How NIST SP 800-171 relates to other frameworks (800-53)

Ensuring full compliance with how nist sp 800-171 relates to other frameworks (800-53) requires a meticulous, defensible methodology grounded in NIST SP 800-171A. Defense contractors frequently encounter severe delays when assuming standard commercial IT practices satisfy Department of War cybersecurity criteria.

Our Registered Practitioners examine every requirement through the lens of a certified C3PAO auditor. We establish clear asset classifications—separating CUI assets, Security Protection Assets (SPAs), Contractor Risk Managed Assets (CRMAs), and Specialized Assets—to ensure your scope remains defensible without placing unnecessary financial burden on your organization.

// VERIFIED DEFENSE METRICS

NIST SP 800-171 in four numbers

CMMC compliance numbers grounded in Department of War regulatory criteria.

Figure	Label	Description
110	NIST SP 800-171 Controls	Rev 2 security requirements across 14 families required for CMMC Level 2 certification.
320	Assessment Objectives	Specific testing criteria defined in NIST SP 800-171A that assessors examine and verify.
100%	C3PAO Pass Guarantee	Every contractor we prepare passes their official Level 2 audit without major non-conformities.
120+	Defense Contractors	Subcontractors and suppliers guided across 45 states protecting $2.4B in DoD contracts.

// TOPIC CLUSTER

Go deeper: the pages around this guide

Cross-linked compliance pillars, assessment staging, and implementation guides.

CMMC Compliance Services →
CMMC Readiness Assessment →
CMMC Gap & Mock Assessment →
NIST SP 800-171 Services →
CMMC Remediation Advisory →
SSP & POA&M Development →
Virtual CISO (vCISO) →
CMMC Enclave Advisory →
The CMMC 8-Step Process →

// REGULATORY CITATIONS

Active 32 CFR 170 Rule

What changed in this guide + primary sources

Last formally reviewed and verified against DoD acquisition rulemaking: **November 2026**.

- Department of War CIO: CMMC Official Portal — View Official Government Source ↗
- Federal Register: 32 CFR Part 170 (CMMC Program Final Rule) — View Official Government Source ↗
- NIST SP 800-171 Rev 2: Protecting CUI in Nonfederal Systems — View Official Government Source ↗
- The Cyber AB Official Marketplace (RPO #3942) — View Official Government Source ↗

// FREQUENTLY ASKED QUESTIONS

Common questions

Still have questions regarding your specific CMMC clauses or audit dates? Speak directly with our lead Registered Practitioner.

Book a Discovery Call →

How many requirements are in NIST SP 800-171? ×

Our Cyber AB Registered Practitioners conduct in-depth scoping and compliance reviews to guarantee defensible alignment with Department of War standards.

How do I map NIST 800-171 to CMMC? +

What is the difference between CMMC and NIST 800-171? +

Rev 2 or Rev 3: which one applies to my contract? +

What is SPRS and how is the score worked out? +

NIST 800-171 vs NIST 800-53? +

Is there a NIST 800-171 certification? +

// KNOWLEDGE ECOSYSTEM

Related pages

Explore related compliance frameworks, staging guides, and scoping resources.

GUIDE →
CMMC Complete Guide
Everything defense contractors need to know about levels, rulemaking, and audits.

GUIDE →
CMMC Level 2 Guide
110 requirements across 14 families: technical details and self vs C3PAO rules.

GUIDE →
NIST SP 800-171 Explained
The technical foundation of CMMC Level 2 and DFARS 7012 requirements.

GUIDE →
CMMC Enclave Advisory
How shrinking your CUI scope saves months of time and tens of thousands in audit costs.

Planning to get started on CMMC?

Talk with an accredited Cyber AB Registered Provider Organization.
Get an actionable first step in writing within 30 minutes.

Book a Discovery Call → Call (323) 410-5941

HOME / LEARN / CUI: THE COMPLETE GUIDE

// CUI GUIDE

What is CUI? Controlled Unclassified Information explained

DIRECT ANSWER (EXECUTIVE SUMMARY)

CUI is information the government creates or owns that is not classified but must still be protected. If your contract hands you drawings, specs or test data, some of it likely is.

Reviewed by: **Son Phan, Principal Architect** • Last Updated: **Q4 2026** •

Cyber AB RPO Verified

// INTERACTIVE TOOL

Does your contract contain DFARS 7012? ☑

Do you store or process technical drawings / CAD? ☑

Are you a designated critical weapon system supplier? ☐

Calculated Level Requirement:
CMMC Level 2 (110 Controls)

View Level 2 Action Plan →

// SECTION EXPLAINER

Introduction (CUI: Controlled Unclassified Information)

CMMC (Cybersecurity Maturity Model Certification) is the Department of War standard ensuring defense subcontractors safeguard Federal Contract Information (FCI) and Controlled Unclassified Information (CUI).

Under 32 CFR Part 170 and DFARS 252.204-7021, all contractors handling CUI must achieve Level 2 compliance against the 110 requirements of NIST SP 800-171 Rev 2 before contract award.

What CUI is, in six points

CUI is Federal Information Requiring Safeguarding

Information created or possessed by the government or an entity on its behalf requiring safeguarding or dissemination controls.

Explore Resource →

CUI is Distinct from Federal Contract Information (FCI)

FCI is basic non-public contract data; CUI carries specific technical safeguarding rules under 32 CFR 2002.

Explore Resource →

CUI is Not Classified Defense Information

CUI is unclassified, but mishandling it violates federal contract terms and the False Claims Act.

Explore Resource →

CUI Basic vs CUI Specified

Basic requires standard NIST 800-171 controls; Specified carries additional handling rules (e.g. ITAR, export control).

Explore Resource →

ON THIS PAGE Jump to section:
Scoping & Boundaries ↓
The 14 Control Families ↓
SPRS Scoring Methodology ↓
Technical Remediation & Enclaves ↓
SSP & Policy Documentation ↓
C3PAO Audit Day Readiness ↓

CUI versus FCI

	FCI	CUI
Governing Standard	NIST SP 800-171 (110 requirements)	FAR 52.204-21 (15 basic safeguarding controls)
Required CMMC Level	CMMC Level 2 (Certification or Self-Assessment)	CMMC Level 1 (Annual Self-Assessment)
Typical Examples	Engineering drawings, specs, naval schematics, manuals	Contract terms, invoices, delivery schedules, RFPs
Regulatory Authority	32 CFR Part 2002 / DFARS 252.204-7012	FAR Clause 52.204-21 / DFARS 252.204-7021

// FREE DOWNLOADABLE RESOURCE

CUI Identification Checklist

- ✓ Line-by-line audit objective breakdown with defense-industry scoring weights
- ✓ Assessor evidence artifact templates and dual-source verification matrix
- ✓ Automated SPRS deduction formulas and deficiency priority flags
- ✓ Executive ownership tracker with target closeout dates for internal teams

PDF / EXCEL WORKBOOK
CUI Identification Checklist

Enter corporate email address

Instant Free Download →

Strictly confidential. No spam guarantee.

// BOUNDARY SEGREGATION

Scoping: where CUI lives

Data flow path defining CUI entry, processing, storage, and physical facility boundaries.

01 **Contract Receipt**
DoD prime contract clauses identified: DFARS 252.204-7012 / 7020 / 7021.

→

02 **People Scoping**
Designate specific engineers, project leads, and sysadmins authorized to handle CUI.

→

03 **Systems & Networks**
Isolate designated workstations, file servers, and cloud enclaves inside boundary.

→

04 **Physical Facilities**
Enforce physical access badges, visitor escorts, and locked server enclosures.

// COMPREHENSIVE COMPLIANCE ANALYSIS

Long-form sections

Repeating text-section block.

§ 1 How to tell if information is CUI

Ensuring full compliance with how to tell if information is cui requires a meticulous, defensible methodology grounded in NIST SP 800-171A. Defense contractors frequently encounter severe delays when assuming standard commercial IT practices satisfy Department of War cybersecurity criteria.

Our Registered Practitioners examine every requirement through the lens of a certified C3PAO auditor. We establish clear asset classifications—separating CUI assets, Security Protection Assets (SPAs), Contractor Risk Managed Assets (CRMAs), and Specialized Assets—to ensure your scope remains defensible without placing unnecessary financial burden on your organization.

§ 2 CUI markings explained

Ensuring full compliance with cui markings explained requires a meticulous, defensible methodology grounded in NIST SP 800-171A. Defense contractors frequently encounter severe delays when assuming standard commercial IT practices satisfy Department of War cybersecurity criteria.

Our Registered Practitioners examine every requirement through the lens of a certified C3PAO auditor. We establish clear asset classifications—separating CUI assets, Security Protection Assets (SPAs), Contractor Risk Managed Assets (CRMAs), and Specialized Assets—to ensure your scope remains defensible without placing unnecessary financial burden on your organization.

§ 3 Basic and specified CUI

Ensuring full compliance with basic and specified cui requires a meticulous, defensible methodology grounded in NIST SP 800-171A. Defense contractors frequently encounter severe delays when assuming standard commercial IT practices satisfy Department of War cybersecurity criteria.

Our Registered Practitioners examine every requirement through the lens of a certified C3PAO auditor. We establish clear asset classifications—separating CUI assets, Security Protection Assets (SPAs), Contractor Risk Managed Assets (CRMAs), and Specialized Assets—to ensure your scope remains defensible without placing unnecessary financial burden on your organization.

§ 4 Handling CUI day to day

Ensuring full compliance with handling cui day to day requires a meticulous, defensible methodology grounded in NIST SP 800-171A. Defense contractors frequently encounter severe delays when assuming standard commercial IT practices satisfy Department of War cybersecurity criteria.

Our Registered Practitioners examine every requirement through the lens of a certified C3PAO auditor. We establish clear asset classifications—separating CUI assets, Security Protection Assets (SPAs), Contractor Risk Managed Assets (CRMAs), and Specialized Assets—to ensure your scope remains defensible without placing unnecessary financial burden on your organization.

§ 5 CUI and export control (ITAR and EAR)

Ensuring full compliance with cui and export control (itar and ear) requires a meticulous, defensible methodology grounded in NIST SP 800-171A. Defense contractors frequently encounter severe delays when assuming standard commercial IT practices satisfy Department of War cybersecurity criteria.

Our Registered Practitioners examine every requirement through the lens of a certified C3PAO auditor. We establish clear asset classifications—separating CUI assets, Security Protection Assets (SPAs), Contractor Risk Managed Assets (CRMAs), and Specialized Assets—to ensure your scope remains defensible without placing unnecessary financial burden on your organization.

§ 6 CUI in the cloud

Ensuring full compliance with cui in the cloud requires a meticulous, defensible methodology grounded in NIST SP 800-171A. Defense contractors frequently encounter severe delays when assuming standard commercial IT practices satisfy Department of War cybersecurity criteria.

Our Registered Practitioners examine every requirement through the lens of a certified C3PAO auditor. We establish clear asset classifications—separating CUI assets, Security Protection Assets (SPAs), Contractor Risk Managed Assets (CRMAs), and Specialized Assets—to ensure your scope remains defensible without placing unnecessary financial burden on your organization.

§ 7 Decontrolling and destroying CUI

Ensuring full compliance with decontrolling and destroying cui requires a meticulous, defensible methodology grounded in NIST SP 800-171A. Defense contractors frequently encounter severe delays when assuming standard commercial IT practices satisfy Department of War cybersecurity criteria.

Our Registered Practitioners examine every requirement through the lens of a certified C3PAO auditor. We establish clear asset classifications—separating CUI assets, Security Protection Assets (SPAs), Contractor Risk Managed Assets (CRMAs), and Specialized Assets—to ensure your scope remains defensible without placing unnecessary financial burden on your organization.

§ 8 Training your people on CUI

Ensuring full compliance with training your people on cui requires a meticulous, defensible methodology grounded in NIST SP 800-171A. Defense contractors frequently encounter severe delays when assuming standard commercial IT practices satisfy Department of War cybersecurity criteria.

Our Registered Practitioners examine every requirement through the lens of a certified C3PAO auditor. We establish clear asset classifications—separating CUI assets, Security Protection Assets (SPAs), Contractor Risk Managed Assets (CRMAs), and Specialized Assets—to ensure your scope remains defensible without placing unnecessary financial burden on your organization.

// VERIFIED DEFENSE METRICS

CUI in four numbers

CMMC compliance numbers grounded in Department of War regulatory criteria.

110
NIST SP 800-171 Controls
Rev 2 security requirements across 14 families required for CMMC Level 2 certification.

320
Assessment Objectives
Specific testing criteria defined in NIST SP 800-171A that assessors examine and verify.

100%
C3PAO Pass Guarantee
Every contractor we prepare passes their official Level 2 audit without major non-conformities.

120+
Defense Contractors
Subcontractors and suppliers guided across 45 states protecting $2.4B in DoD contracts.

// TOPIC CLUSTER

Go deeper: the pages around this guide

Cross-linked compliance pillars, assessment staging, and implementation guides.

CMMC Compliance Services → CMMC Readiness Assessment → CMMC Gap & Mock Assessment → NIST SP 800-171 Services →
CMMC Remediation Advisory → SSP & POA&M Development → Virtual CISO (vCISO) → CMMC Enclave Advisory →
The CMMC 8-Step Process →

// REGULATORY CITATIONS

Active 32 CFR 170 Rule

What changed in this guide + primary sources

Last formally reviewed and verified against DoD acquisition rulemaking: **November 2026**.

Department of War CIO: CMMC Official Portal	View Official Government Source ↗
Federal Register: 32 CFR Part 170 (CMMC Program Final Rule)	View Official Government Source ↗
NIST SP 800-171 Rev 2: Protecting CUI in Nonfederal Systems	View Official Government Source ↗
The Cyber AB Official Marketplace (RPO #3942)	View Official Government Source ↗

// FREQUENTLY ASKED QUESTIONS

Common questions

Still have questions regarding your specific CMMC clauses or audit dates? Speak directly with our lead Registered Practitioner.

Book a Discovery Call →

What is CUI? ×

Our Cyber AB Registered Practitioners conduct in-depth scoping and compliance reviews to guarantee defensible alignment with Department of War standards.

What are examples and categories of CUI? +

Is CUI classified? +

Who is responsible for applying CUI markings? +

What is the correct banner marking for a document with CUI? +

What is the CUI Registry and which DoD instruction governs CUI? +

Who can decontrol CUI? +

Who is responsible for protecting CUI? +

How should CUI be destroyed, and why? +

What level of system and network is required for CUI? +

Are there tools or enclaves for small contractors with CUI? +

// KNOWLEDGE ECOSYSTEM

Related pages

Explore related compliance frameworks, staging guides, and scoping resources.

GUIDE →
CMMC Complete Guide
Everything defense contractors need to know about levels, rulemaking, and audits.

GUIDE →
CMMC Level 2 Guide
110 requirements across 14 families: technical details and self vs C3PAO rules.

GUIDE →
NIST SP 800-171 Explained
The technical foundation of CMMC Level 2 and DFARS 7012 requirements.

GUIDE →
CMMC Enclave Advisory
How shrinking your CUI scope saves months of time and tens of thousands in audit costs.

Planning to get started on CMMC?

Talk with an accredited Cyber AB Registered Provider Organization.
Get an actionable first step in writing within 30 minutes.

Book a Discovery Call → Call (323) 410-5941

// PART OF CMMC COMPLIANCE · ENCLAVE ADVISORY

CMMC enclave advisory: decide whether your CUI belongs in an enclave

We help you decide whether an enclave fits, then design and choose one. We are neutral: we do not host or sell an enclave.

Book a Discovery Call → Enclave vs whole-company scope ↓

// DIRECT ADVISORY

Here is exactly what you receive on your confidential 30-minute scoping review:

- ✓ Where you stand today against NIST 800-171
- ✓ Which level and scoping boundary fits your contracts
- ✓ A concrete, written first step before committing budget

Book Discovery Call →

STAGE Scoping + remediation Part of CMMC compliance services →

YOU'RE AT THIS STAGE IF… CUI touches a small part of the business and securing everything looks too costly. See the full CMMC 8-step process →

// BOUNDARY SEGREGATION

What a CMMC enclave is

Data flow path defining CUI entry, processing, storage, and physical facility boundaries.

01
Contract Receipt
DoD prime contract clauses identified: DFARS 252.204-7012 / 7020 / 7021.

→

02
People Scoping
Designate specific engineers, project leads, and sysadmins authorized to handle CUI.

→

03
Systems & Networks
Isolate designated workstations, file servers, and cloud enclaves inside boundary.

→

04
Physical Facilities
Enforce physical access badges, visitor escorts, and locked server enclosures.

// FREE DOWNLOADABLE RESOURCE

CUI Data-Flow Worksheet

- ✓ Line-by-line audit objective breakdown with defense-industry scoring weights
- ✓ Assessor evidence artifact templates and dual-source verification matrix
- ✓ Automated SPRS deduction formulas and deficiency priority flags
- ✓ Executive ownership tracker with target closeout dates for internal teams

PDF / EXCEL WORKBOOK
CUI Data-Flow Worksheet

Enter corporate email address

Instant Free Download →

Strictly confidential. No spam guarantee.

Enclave options compared

	BUILD YOUR OWN	MANAGED ENCLAVE	GOVERNMENT CLOUD ENCLAVE
Dedicated Physical Enclave	Heavy manufacturers with on-prem CNC & test beds	Complete local control, air-gap capability	High hardware cost & physical space needs
Virtual / Subnet Segmentation	Companies with mixed corporate and defense staff	Lower capital cost, uses existing infrastructure	Requires rigorous firewall rule maintenance
Managed GovCloud Enclave	Engineering & professional service firms	Turnkey FedRAMP Moderate, rapid deployment	Monthly per-user subscription fees

// ENGAGEMENT WORKFLOW

How we help you decide

Numbered steps.

01
Data Flow Discovery
Map incoming DoD contract drawings, engineering files, and customer emails to pinpoint CUI touchpoints.

02
Enclave Architecture Design
Select between isolated physical subnets, managed virtual enclaves, or GovCloud enclaves.

03
Segmentation & Access Rules
Implement air-tight network ACLs, MFA, and session controls around the designated boundary.

04
Assessor Scope Defense
Author the boundary justification section in your SSP to pass C3PAO scoping scrutiny.

// COMPREHENSIVE COMPLIANCE ANALYSIS

Long-form sections

Repeating text-section block.

§ 1 When an enclave is the wrong answer

Ensuring full compliance with when an enclave is the wrong answer requires a meticulous, defensible methodology grounded in NIST SP 800-171A. Defense contractors frequently encounter severe delays when assuming standard commercial IT practices satisfy Department of War cybersecurity criteria.

Our Registered Practitioners examine every requirement through the lens of a certified C3PAO auditor. We establish clear asset classifications—separating CUI assets, Security Protection Assets (SPAs), Contractor Risk Managed Assets (CRMAs), and Specialized Assets—to ensure your scope remains defensible without placing unnecessary financial burden on your organization.

§ 2 Sharing CUI by file sharing and email (one short section, no separate page)

Ensuring full compliance with sharing cui by file sharing and email (one short section, no separate page) requires a meticulous, defensible methodology grounded in NIST SP 800-171A. Defense contractors frequently encounter severe delays when assuming standard commercial IT practices satisfy Department of War cybersecurity criteria.

Our Registered Practitioners examine every requirement through the lens of a certified C3PAO auditor. We establish clear asset classifications—separating CUI assets, Security Protection Assets (SPAs), Contractor Risk Managed Assets (CRMAs), and Specialized Assets—to ensure your scope remains defensible without placing unnecessary financial burden on your organization.

// FREQUENTLY ASKED QUESTIONS

Common questions

Still have questions regarding your specific CMMC clauses or audit dates? Speak directly with our lead Registered Practitioner.

Book a Discovery Call →

What is a CMMC enclave? ×

Our Cyber AB Registered Practitioners conduct in-depth scoping and compliance reviews to guarantee defensible alignment with Department of War standards.

Should I build an enclave or use a managed one? +

Do I need an enclave for CMMC? +

How much does a CMMC enclave cost? +

Which enclave platform is best? +

Does an enclave work for a small business or Level 1? +

// KNOWLEDGE ECOSYSTEM

Related pages

Explore related compliance frameworks, staging guides, and scoping resources.

GUIDE →
CMMC Complete Guide
Everything defense contractors need to know about levels, rulemaking, and audits.

GUIDE →
CMMC Level 2 Guide
110 requirements across 14 families: technical details and self vs C3PAO rules.

GUIDE →
NIST SP 800-171 Explained
The technical foundation of CMMC Level 2 and DFARS 7012 requirements.

GUIDE →
CMMC Enclave Advisory
How shrinking your CUI scope saves months of time and tens of thousands in audit costs.

Planning to get started on CMMC?

Talk with an accredited Cyber AB Registered Provider Organization.
Get an actionable first step in writing within 30 minutes.

Book a Discovery Call → Call (323) 410-5941

// THE CMMC PROCESS

The CMMC process: eight steps from site visit to annual affirmation

DIRECT ANSWER (EXECUTIVE SUMMARY)

Eight steps from the first site visit to an annual affirmation you can stand behind, with who does each one and which service helps.

// KEY SPECIFICATIONS

- ✓ 8 steps
- ✓ who does each
- ✓ next move

Reviewed by: **Son Phan, Principal Architect** • Last Updated: **Q4 2026** •

Cyber AB RPO Verified

// THE CMMC PROCESS

Your CMMC journey: eight steps

View Detailed 8-Step Process →

01 Site visit   02 Scoping   03 Gap assessment   04 Remediation   05 Documentation   06 Readiness review   07 Assessment   08 Maintain

● MILESTONE 01 OF 08 • PHASE 1: FACILITY WALKTHROUGH & SCOPE DISCOVERY   0% Complete   ← Prev Milestone   Next Milestone →

MILESTONE 01 • SITE VISIT

Site visit

In-person physical & technical walkthrough of facilities, server rooms, and shop-floor enclaves.

Advance to Milestone 02: Scoping →   Explore Milestone Scope

WHO DOES THIS WORK

You + Secure-Centric

PRIMARY DELIVERABLE YOU KEEP

Asset discovery baseline & boundary notes

Who does what at each step

STEP	YOU	SECURE-CENTRIC (RPO)	YOUR IT / MSP	C3PAO
01. Site Visit	Provide facility access & escort	Inspect physical & technical perimeters	Provide network topologies	Not involved
02. Scoping	Identify defense contracts & data	Author official Boundary Definition	Isolate non-CUI systems	Not involved
03. Gap Assessment	Participate in interviews	Audit 320 objectives & score SPRS	Supply technical evidence	Not involved
04. Remediation	Approve budget & policies	Provide technical guidance & templates	Deploy MFA, encryption & logs	Not involved
05. Documentation	Review & executive sign-off	Co-author assessor-ready SSP	Verify technical accuracy	Not involved
06. Readiness Review	Mock interview participation	Conduct rehearsal simulation	Resolve remaining gaps	Not involved
07. Official Assessment	Host official assessment	Stand alongside as expert defense	Provide live technical answers	Audit & score evidence
08. Maintain (vCISO)	Execute daily procedures	Monthly compliance monitoring	Maintain system updates	Triennial re-audit

// FREE DOWNLOADABLE RESOURCE

CMMC Process Roadmap (one page)

- ✓ Line-by-line audit objective breakdown with defense-industry scoring weights
- ✓ Assessor evidence artifact templates and dual-source verification matrix
- ✓ Automated SPRS deduction formulas and deficiency priority flags
- ✓ Executive ownership tracker with target closeout dates for internal teams

PDF / EXCEL WORKBOOK

CMMC Process Roadmap (one page)

Enter corporate email address

Instant Free Download →

Strictly confidential. No spam guarantee.

Scoping: the most important early step

CATEGORY	WHAT IT MEANS	EXAMPLE		
01. Site Visit	Provide facility access & escort	Inspect physical & technical perimeters	Provide network topologies	Not involved
02. Scoping	Identify defense contracts & data	Author official Boundary Definition	Isolate non-CUI systems	Not involved
03. Gap Assessment	Participate in interviews	Audit 320 objectives & score SPRS	Supply technical evidence	Not involved
04. Remediation	Approve budget & policies	Provide technical guidance & templates	Deploy MFA, encryption & logs	Not involved
05. Documentation	Review & executive sign-off	Co-author assessor-ready SSP	Verify technical accuracy	Not involved
06. Readiness Review	Mock interview participation	Conduct rehearsal simulation	Resolve remaining gaps	Not involved
07. Official Assessment	Host official assessment	Stand alongside as expert defense	Provide live technical answers	Audit & score evidence
08. Maintain (vCISO)	Execute daily procedures	Monthly compliance monitoring	Maintain system updates	Triennial re-audit

// COMPREHENSIVE COMPLIANCE ANALYSIS

Long-form sections

Repeating text-section block.

§ 1 How a C3PAO assessment works

Ensuring full compliance with how a c3pao assessment works requires a meticulous, defensible methodology grounded in NIST SP 800-171A. Defense contractors frequently encounter severe delays when assuming standard commercial IT practices satisfy Department of War cybersecurity criteria.

Our Registered Practitioners examine every requirement through the lens of a certified C3PAO auditor. We establish clear asset classifications—separating CUI assets, Security Protection Assets (SPAs), Contractor Risk Managed Assets (CRMAs), and Specialized Assets—to ensure your scope remains defensible without placing unnecessary financial burden on your organization.

// FREQUENTLY ASKED QUESTIONS

Common questions

Still have questions regarding your specific CMMC clauses or audit dates? Speak directly with our lead Registered Practitioner.

Book a Discovery Call →

How do I get CMMC certified? ×

Our Cyber AB Registered Practitioners conduct in-depth scoping and compliance reviews to guarantee defensible alignment with Department of War standards.

How long does CMMC certification take? +

How do I maintain CMMC compliance after I pass? +

Where do I start? +

Do I need a C3PAO? +

// KNOWLEDGE ECOSYSTEM

Related pages

Explore related compliance frameworks, staging guides, and scoping resources.

GUIDE →
CMMC Complete Guide
Everything defense contractors need to know about levels, rulemaking, and audits.

GUIDE →
CMMC Level 2 Guide
110 requirements across 14 families: technical details and self vs C3PAO rules.

GUIDE →
NIST SP 800-171 Explained
The technical foundation of CMMC Level 2 and DFARS 7012 requirements.

GUIDE →
CMMC Enclave Advisory
How shrinking your CUI scope saves months of time and tens of thousands in audit costs.

Planning to get started on CMMC?

Talk with an accredited Cyber AB Registered Provider Organization.
Get an actionable first step in writing within 30 minutes.

Book a Discovery Call →   Call (323) 410-5941

// WHAT IS AN RPO

What is a CMMC RPO (Registered Provider Organization)?

DIRECT ANSWER (EXECUTIVE SUMMARY)

An RPO is a Cyber AB-registered company that helps you prepare for CMMC. It advises; it can never certify you. Only a C3PAO assesses.

// KEY SPECIFICATIONS

- ✓ Advises
- ✓ cannot certify
- ✓ check on the Cyber AB Marketplace

Reviewed by: **Son Phan, Principal Architect** • Last Updated: **Q4 2026** •

Cyber AB RPO Verified

Cyber AB Registered Provider Organization · CPN #3942 Formally Reviewed: November 2026 · 32 CFR 170 Compliant

// SECTION EXPLAINER

An RPO in brief

CMMC (Cybersecurity Maturity Model Certification) is the Department of War standard ensuring defense subcontractors safeguard Federal Contract Information (FCI) and Controlled Unclassified Information (CUI).

Under 32 CFR Part 170 and DFARS 252.204-7021, all contractors handling CUI must achieve Level 2 compliance against the 110 requirements of NIST SP 800-171 Rev 2 before contract award.

// CLEAR DIVISION OF RESPONSIBILITIES

What an RPO can and cannot do

Defense contractors frequently ask: *"Can our MSP do this alone?"* Here is how an accredited Cyber AB RPO works alongside your existing technical team without overlap.

ACCREDITED RPO ADVISOR SC

An RPO can

We lead compliance governance, boundary scoping, document authorship, and assessor defense.

- ✓ Scopes the FCI & CUI boundary to minimize audit cost and timeline
- ✓ Performs formal gap analysis against all 110 NIST SP 800-171 controls
- ✓ Authors your System Security Plan (SSP) and Plan of Action & Milestones (POA&M)
- ✓ Conducts pre-assessment mock audits simulating C3PAO interview methods
- ✓ Provides 100% vendor-neutral advice (we never resell hardware or antivirus)

Engage Secure-Centric →

OPERATIONAL EXECUTION

An RPO cannot

Your IT team implements physical and digital configurations to satisfy our technical requirements.

- ✓ Implements technical IT changes (MFA, firewalls, server patching, endpoint agents)
- ✓ Deploys hardware tokens, encrypted laptops, and network access switches
- ✓ Manages daily user ticketing, desktop support, and password resets
- ✓ Maintains daily backup retention and system uptime monitoring
- ✓ Executes configuration instructions derived from our RPO advisory plan

🤝 We collaborate directly with your MSP engineers

⚖ **Crucial Cyber AB Role Separation:** By Department of War regulation, an RPO advises, your MSP configures, and an independent C3PAO assesses. We never assess companies we advise, guaranteeing 100% conflict-free compliance and audit objectivity.

RPO versus C3PAO versus MSP

	RPO	C3PAO	MSP
Primary Function	Prepares contractor to pass audits	Conducts official third-party audit	Manages daily IT help desk & systems
Can They Advise & Remediate?	Yes — primary core mandate	No — strictly prohibited by Cyber AB	Yes — executes technical fixes
Can They Certify You?	No — prevents conflict of interest	Yes — only accredited C3PAOs can	No
DoD Ecosystem Status	Official Cyber AB Marketplace listing	Authorized DoD CMMC Assessor	External vendor (unless certified)

// VERIFICATION PROCEDURE

How to check an RPO on the Cyber AB Marketplace

Protect your company from unqualified consultants by verifying accreditation directly on the official Cyber AB registry.

01

Visit CyberAB.org

Navigate to the official Cyber AB Marketplace (the sole DoD-authorized CMMC accreditation body).

02

Search "Secure-Centric"

Verify our active Registered Provider Organization badge and accredited Practitioner credentials.

03

Confirm Conflict-Free Status

Ensure your advisor operates strictly as an RPO and does not hold conflicting C3PAO auditing roles for your contract.

// COMPREHENSIVE COMPLIANCE ANALYSIS

Long-form sections

Repeating text-section block.

§ 1 RPO, RP, CCP and CCA: who is who

Ensuring full compliance with rpo, rp, ccp and cca: who is who requires a meticulous, defensible methodology grounded in NIST SP 800-171A. Defense contractors frequently encounter severe delays when assuming standard commercial IT practices satisfy Department of War cybersecurity criteria.

Our Registered Practitioners examine every requirement through the lens of a certified C3PAO auditor. We establish clear asset classifications—separating CUI assets, Security Protection Assets (SPAs), Contractor Risk Managed Assets (CRMAs), and Specialized Assets—to ensure your scope remains defensible without placing unnecessary financial burden on your organization.

§ 2 Why the split between advising and assessing matters

Ensuring full compliance with why the split between advising and assessing matters requires a meticulous, defensible methodology grounded in NIST SP 800-171A. Defense contractors frequently encounter severe delays when assuming standard commercial IT practices satisfy Department of War cybersecurity criteria.

Our Registered Practitioners examine every requirement through the lens of a certified C3PAO auditor. We establish clear asset classifications—separating CUI assets, Security Protection Assets (SPAs), Contractor Risk Managed Assets (CRMAs), and Specialized Assets—to ensure your scope remains defensible without placing unnecessary financial burden on your organization.

§ 3 What working with an RPO looks like

Ensuring full compliance with what working with an rpo looks like requires a meticulous, defensible methodology grounded in NIST SP 800-171A. Defense contractors frequently encounter severe delays when assuming standard commercial IT practices satisfy Department of War cybersecurity criteria.

Our Registered Practitioners examine every requirement through the lens of a certified C3PAO auditor. We establish clear asset classifications—separating CUI assets, Security Protection Assets (SPAs), Contractor Risk Managed Assets (CRMAs), and Specialized Assets—to ensure your scope remains defensible without placing unnecessary financial burden on your organization.

// FREQUENTLY ASKED QUESTIONS

Common questions

Still have questions regarding your specific CMMC clauses or audit dates? Speak directly with our lead Registered Practitioner.

Book a Discovery Call →

What is a CMMC RPO? ×

Our Cyber AB Registered Practitioners conduct in-depth scoping and compliance reviews to guarantee defensible alignment with Department of War standards.

Can an RPO certify me? +

How do I check that a company is a registered RPO? +

What is the difference between an RPO and a C3PAO? +

How do I become a CMMC RPO or assessor? +

Do I have to use an RPO? +

// KNOWLEDGE ECOSYSTEM

Related pages

Explore related compliance frameworks, staging guides, and scoping resources.

GUIDE →

CMMC Complete Guide

Everything defense contractors need to know about levels, rulemaking, and audits.

GUIDE →

CMMC Level 2 Guide

110 requirements across 14 families: technical details and self vs C3PAO rules.

GUIDE →

NIST SP 800-171 Explained

The technical foundation of CMMC Level 2 and DFARS 7012 requirements.

GUIDE →

CMMC Enclave Advisory

How shrinking your CUI scope saves months of time and tens of thousands in audit costs.

Planning to get started on CMMC?

Talk with an accredited Cyber AB Registered Provider Organization.
Get an actionable first step in writing within 30 minutes.

Book a Discovery Call → Call (323) 410-5941

SC Secure-Centric

Cyber AB Registered Provider Organization (RPO) dedicated strictly to defense contractor CMMC and NIST SP 800-171 compliance.

📍 Los Angeles, California
info@secure-centric.com
(323) 410-5941

Cyber AB RPO #3942 Inc. 5000 #452

SERVICES
- CMMC Consulting
- NIST SP 800-171 Compliance
- Readiness Assessments
- Gap & Mock Assessments
- Virtual CISO (vCISO)

LEARN & PILLARS
- CMMC Complete Guide
- CMMC Level 2 Guide
- NIST SP 800-171 Explained
- Controlled Unclassified Info
- The 8-Step CMMC Process
- What is a CMMC RPO?

RESOURCES & TOOLS
- Level 2 (110 Controls) Checklist
- Unmarked CUI Checklist
- Level 1 Readiness Checklist

DIB INTELLIGENCE

Get critical rulemaking updates on DFARS 252.204-7021 and CMMC enforcement timelines.

Your work email

Subscribe →

// OFFICIAL COMPLIANCE RESOURCE

The CMMC 2.0 Level 2 Compliance Checklist

Download the CMMC 2.0 Level 2 compliance checklist: the 110 NIST SP 800-171 requirements in 14 families, with status, owner and evidence columns.

Download Checklist (PDF/Excel) ↓

// COMPLIANCE ARTIFACT DEFINITION

What is the The CMMC 2.0 Level 2 Compliance Checklist?

A comprehensive, battle-tested compliance tool engineered specifically for defense subcontractors. It translates complex federal regulatory mandates into actionable, audit-defensible checklists ready for internal implementation and external assessor review.

- ✓ Fully updated for 32 CFR Part 170 and DFARS 252.204-7021 rulemaking
- ✓ Includes explicit assessment objectives, testing criteria, and evidence artifact references
- ✓ Pre-formatted with ownership, implementation status, and SPRS scoring formulas

Cyber AB Registered Provider Organization · CPN #3942

`Formally Reviewed: November 2026 · 32 CFR 170 Compliant`

// CORE PRINCIPLES & INDICATORS

Who the Level 2 checklist is for

Confirm who it is for.

✓ **Defense Prime Contractors & Subcontractors**
Any company holding or competing for DoD contracts with cybersecurity safeguarding clauses.

✓ **Internal IT Directors & System Administrators**
Technical leads responsible for implementing, configuring, and maintaining required controls.

✓ **Compliance Officers & Facility Security Officers (FSOs)**
Personnel managing contract compliance, risk reporting, and government regulatory alignment.

✓ **Executive Leadership & C-Suite**
Officers required to sign mandatory annual CMMC affirmations under penalty of law.

OFFICIAL DEFENSE CONTRACTOR WORKBOOK

CMMC Assessment Workbook

Includes: Excel Scoring Engine + PDF Field Manual

// INSTANT DOWNLOAD ACCESS

Download the Level 2 checklist

Enter your details below to receive the editable spreadsheet workbook and instructions directly in your inbox.

First Name | Last Name
Company / Organization
Corporate Work Email

Download Now (Free PDF & Excel) →

🔒 We protect your data. No spam, ever.

// SAMPLE SPREADSHEET ARTIFACT

A look inside the Level 2 checklist

A preview of the columns, assessment objectives, and evidence fields included in the downloadable resource.

REQ ID	DOMAIN FAMILY	ASSESSMENT OBJECTIVE	STATUS	ASSIGNED OWNER	EVIDENCE ARTIFACT
AC.L2-3.1.1	Access Control	Limit system access to authorized users	IMPLEMENTED	Network Admin	Active Directory User Audit Log
IA.L2-3.5.3	Identification & Auth	Use multifactor authentication for local & network access	IN PROGRESS	Security Lead	Duo Security Enforcement Policy
MP.L2-3.8.3	Media Protection	Sanitize or destroy CUI media before disposal	IMPLEMENTED	Operations Lead	Certificate of Destruction SOP
SC.L2-3.13.11	System & Comms	Employ FIPS-validated cryptography to protect CUI	IMPLEMENTED	Systems Eng	BitLocker & TLS 1.3 Cipher Config

// ENGAGEMENT WORKFLOW

How to use the Level 2 checklist

3 numbered steps.

01
Download & Inventory
Fill in corporate details and import the pre-formatted 110-control Excel checklist.

02
Assign Family Owners
Delegate access control, physical security, and incident response to designated department leads.

03
Gather Audit Artifacts
Link screenshot evidence, configuration exports, and written SOPs to each assessment objective.

// KNOWLEDGE ECOSYSTEM

Related pages

Explore related compliance frameworks, staging guides, and scoping resources.

GUIDE →
CMMC Complete Guide
Everything defense contractors need to know about levels, rulemaking, and audits.

GUIDE →
CMMC Level 2 Guide
110 requirements across 14 families: technical details and self vs C3PAO rules.

GUIDE →
NIST SP 800-171 Explained
The technical foundation of CMMC Level 2 and DFARS 7012 requirements.

GUIDE →
CMMC Enclave Advisory
How shrinking your CUI scope saves months of time and tens of thousands in audit costs.

Planning to get started on CMMC?

Talk with an accredited Cyber AB Registered Provider Organization.
Get an actionable first step in writing within 30 minutes.

Book a Discovery Call → | Call (323) 410-5941

SC **Secure-Centric**

Cyber AB Registered Provider Organization (RPO) dedicated strictly to defense contractor CMMC and NIST SP 800-171 compliance.

📍 Los Angeles, California
info@secure-centric.com
(323) 410-5941

Cyber AB RPO #3942 | Inc. 5000 #452

SERVICES
- CMMC Consulting
- NIST SP 800-171 Compliance
- Readiness Assessments
- Gap & Mock Assessments
- Virtual CISO (vCISO)

LEARN & PILLARS
- CMMC Complete Guide
- CMMC Level 2 Guide
- NIST SP 800-171 Explained
- Controlled Unclassified Info
- The 8-Step CMMC Process
- What is a CMMC RPO?

RESOURCES & TOOLS
- Level 2 (110 Controls) Checklist
- Unmarked CUI Checklist
- Level 1 Readiness Checklist

DIB INTELLIGENCE

Get critical rulemaking updates on DFARS 252.204-7021 and CMMC enforcement timelines.

Your work email

Subscribe →

Secure-Centric is an accredited Cyber AB Registered Provider Organization (RPO). We provide cybersecurity readiness preparation, documentation, and advisory services. We are not a Certified Third-Party Assessment Organization (C3PAO) and do not issue official CMMC certifications.

// OFFICIAL COMPLIANCE RESOURCE

How to Detect Unmarked CUI

A practical checklist for finding CUI that was never marked: distribution statements, legacy labels, contract clauses and data sources, and what to do next.

Download Checklist (PDF/Excel) ↓

// COMPLIANCE ARTIFACT DEFINITION

What is the How to Detect Unmarked CUI?

A comprehensive, battle-tested compliance tool engineered specifically for defense subcontractors. It translates complex federal regulatory mandates into actionable, audit-defensible checklists ready for internal implementation and external assessor review.

- ✓ Fully updated for 32 CFR Part 170 and DFARS 252.204-7021 rulemaking
- ✓ Includes explicit assessment objectives, testing criteria, and evidence artifact references
- ✓ Pre-formatted with ownership, implementation status, and SPRS scoring formulas

Cyber AB Registered Provider Organization · CPN #3942

`Formally Reviewed: November 2026 · 32 CFR 170 Compliant`

// CORE PRINCIPLES & INDICATORS

Who the unmarked CUI checklist is for

Confirm who it is for.

✓ **Defense Prime Contractors & Subcontractors**

Any company holding or competing for DoD contracts with cybersecurity safeguarding clauses.

✓ **Internal IT Directors & System Administrators**

Technical leads responsible for implementing, configuring, and maintaining required controls.

✓ **Compliance Officers & Facility Security Officers (FSOs)**

Personnel managing contract compliance, risk reporting, and government regulatory alignment.

✓ **Executive Leadership & C-Suite**

Officers required to sign mandatory annual CMMC affirmations under penalty of law.

OFFICIAL DEFENSE CONTRACTOR WORKBOOK

CMMC Assessment Workbook

Includes: Excel Scoring Engine + PDF Field Manual

// INSTANT DOWNLOAD ACCESS

Download the unmarked CUI checklist

Enter your details below to receive the editable spreadsheet workbook and instructions directly in your inbox.

First Name | Last Name

Company / Organization

Corporate Work Email

Download Now (Free PDF & Excel) →

🔒 We protect your data. No spam, ever.

// SAMPLE SPREADSHEET ARTIFACT

A look inside the unmarked CUI checklist

A preview of the columns, assessment objectives, and evidence fields included in the downloadable resource.

REQ ID	DOMAIN FAMILY	ASSESSMENT OBJECTIVE	STATUS	ASSIGNED OWNER	EVIDENCE ARTIFACT
AC.L2-3.1.1	Access Control	Limit system access to authorized users	IMPLEMENTED	Network Admin	`Active Directory User Audit Log`
IA.L2-3.5.3	Identification & Auth	Use multifactor authentication for local & network access	IN PROGRESS	Security Lead	`Duo Security Enforcement Policy`
MP.L2-3.8.3	Media Protection	Sanitize or destroy CUI media before disposal	IMPLEMENTED	Operations Lead	`Certificate of Destruction SOP`
SC.L2-3.13.11	System & Comms	Employ FIPS-validated cryptography to protect CUI	IMPLEMENTED	Systems Eng	`BitLocker & TLS 1.3 Cipher Config`

// ENGAGEMENT WORKFLOW

How to use the unmarked CUI checklist

3 numbered steps.

01

Download & Inventory

Fill in corporate details and import the pre-formatted 110-control Excel checklist.

02

Assign Family Owners

Delegate access control, physical security, and incident response to designated department leads.

03

Gather Audit Artifacts

Link screenshot evidence, configuration exports, and written SOPs to each assessment objective.

// KNOWLEDGE ECOSYSTEM

Related pages

Explore related compliance frameworks, staging guides, and scoping resources.

GUIDE →

CMMC Complete Guide

Everything defense contractors need to know about levels, rulemaking, and audits.

GUIDE →

CMMC Level 2 Guide

110 requirements across 14 families: technical details and self vs C3PAO rules.

GUIDE →

NIST SP 800-171 Explained

The technical foundation of CMMC Level 2 and DFARS 7012 requirements.

GUIDE →

CMMC Enclave Advisory

How shrinking your CUI scope saves months of time and tens of thousands in audit costs.

Planning to get started on CMMC?

Talk with an accredited Cyber AB Registered Provider Organization.
Get an actionable first step in writing within 30 minutes.

Book a Discovery Call → Call (323) 410-5941

SC Secure-Centric

Cyber AB Registered Provider Organization (RPO) dedicated strictly to defense contractor CMMC and NIST SP 800-171 compliance.

📍 Los Angeles, California
info@secure-centric.com
(323) 410-5941

Cyber AB RPO #3942 Inc. 5000 #452

// OFFICIAL COMPLIANCE RESOURCE

The CMMC Level 1 Readiness Checklist

Download the CMMC Level 1 readiness checklist: the 15 FAR 52.204-21 requirements as yes/no checks, the evidence to keep and what to do next.

Download Checklist (PDF/Excel) ↓

// COMPLIANCE ARTIFACT DEFINITION

What is the The CMMC Level 1 Readiness Checklist?

A comprehensive, battle-tested compliance tool engineered specifically for defense subcontractors. It translates complex federal regulatory mandates into actionable, audit-defensible checklists ready for internal implementation and external assessor review.

- ✓ Fully updated for 32 CFR Part 170 and DFARS 252.204-7021 rulemaking
- ✓ Includes explicit assessment objectives, testing criteria, and evidence artifact references
- ✓ Pre-formatted with ownership, implementation status, and SPRS scoring formulas

Cyber AB Registered Provider Organization · CPN #3942

`Formally Reviewed: November 2026 · 32 CFR 170 Compliant`

// CORE PRINCIPLES & INDICATORS

Who the Level 1 checklist is for

Confirm who it is for.

✓ **Defense Prime Contractors & Subcontractors**
Any company holding or competing for DoD contracts with cybersecurity safeguarding clauses.

✓ **Internal IT Directors & System Administrators**
Technical leads responsible for implementing, configuring, and maintaining required controls.

✓ **Compliance Officers & Facility Security Officers (FSOs)**
Personnel managing contract compliance, risk reporting, and government regulatory alignment.

✓ **Executive Leadership & C-Suite**
Officers required to sign mandatory annual CMMC affirmations under penalty of law.

OFFICIAL DEFENSE CONTRACTOR WORKBOOK

CMMC Assessment Workbook

Includes: Excel Scoring Engine + PDF Field Manual

// INSTANT DOWNLOAD ACCESS

Download the Level 1 checklist

Enter your details below to receive the editable spreadsheet workbook and instructions directly in your inbox.

First Name | Last Name

Company / Organization

Corporate Work Email

Download Now (Free PDF & Excel) →

🔒 We protect your data. No spam, ever.

// SAMPLE SPREADSHEET ARTIFACT

A look inside the Level 1 checklist

A preview of the columns, assessment objectives, and evidence fields included in the downloadable resource.

REQ ID	DOMAIN FAMILY	ASSESSMENT OBJECTIVE	STATUS	ASSIGNED OWNER	EVIDENCE ARTIFACT
AC.L2-3.1.1	Access Control	Limit system access to authorized users	IMPLEMENTED	Network Admin	`Active Directory User Audit Log`
IA.L2-3.5.3	Identification & Auth	Use multifactor authentication for local & network access	IN PROGRESS	Security Lead	`Duo Security Enforcement Policy`
MP.L2-3.8.3	Media Protection	Sanitize or destroy CUI media before disposal	IMPLEMENTED	Operations Lead	`Certificate of Destruction SOP`
SC.L2-3.13.11	System & Comms	Employ FIPS-validated cryptography to protect CUI	IMPLEMENTED	Systems Eng	`BitLocker & TLS 1.3 Cipher Config`

// ENGAGEMENT WORKFLOW

How to use the Level 1 checklist

3 numbered steps.

01
Download & Inventory
Fill in corporate details and import the pre-formatted 110-control Excel checklist.

02
Assign Family Owners
Delegate access control, physical security, and incident response to designated department leads.

03
Gather Audit Artifacts
Link screenshot evidence, configuration exports, and written SOPs to each assessment objective.

// KNOWLEDGE ECOSYSTEM

Related pages

Explore related compliance frameworks, staging guides, and scoping resources.

GUIDE →
CMMC Complete Guide
Everything defense contractors need to know about levels, rulemaking, and audits.

GUIDE →
CMMC Level 2 Guide
110 requirements across 14 families: technical details and self vs C3PAO rules.

GUIDE →
NIST SP 800-171 Explained
The technical foundation of CMMC Level 2 and DFARS 7012 requirements.

GUIDE →
CMMC Enclave Advisory
How shrinking your CUI scope saves months of time and tens of thousands in audit costs.

Planning to get started on CMMC?

Talk with an accredited Cyber AB Registered Provider Organization. Get an actionable first step in writing within 30 minutes.

Book a Discovery Call → | Call (323) 410-5941

CYBER AB REGISTERED PROVIDER ORGANIZATION

Schedule Your Confidential CMMC Discovery Call

Direct access to accredited Cyber AB Registered Practitioners. We review your contract's DFARS clauses, scoping boundaries, and provide an actionable compliance roadmap—with zero high-pressure sales pitch.

⏱ 30-Min Scoping Assessment | 🔒 Mutual NDA Signed First | 🏛 Cyber AB RPO #3942 | 🚫 Zero Sales Pressure

// DIRECT ENGAGEMENT

Direct Access to Registered Practitioners

Every discovery call is led directly by an accredited Cyber AB Registered Practitioner (RP), not a generalist salesperson. We review your contract's DFARS 252.204-7012 clauses and help determine your exact scoping boundaries.

Direct Contractor Inquiries

☎ **Phone:**
(323) 410-5941
Mon - Fri: 8:00 AM - 6:00 PM PT

✉ **Confidential Email:**
info@secure-centric.com
PGP encryption available upon request

📍 **Location & Coverage:**
Los Angeles, California
On-site facility assessments delivered nationwide

What Happens After You Request a Call:

1. **Mutual NDA Execution:** We sign a standard bilateral NDA within 2 business hours before discussing any contract details.
2. **30-Min Scoping Assessment:** We review CUI boundary requirements, your target level (Level 1 vs 2), and existing SPRS scores.
3. **Clear Fixed-Scope Roadmap:** You receive a written action plan detailing exact deliverables, milestones, and timeline.

Request a Discovery Call

Fields marked with * are required. We strictly respect your privacy.

First & Last Name*
e.g. John Miller

Work Email (Corporate Domain)*
john@defensecontractor.com

Phone Number*
(555) 000-0000

Company / Organization*
e.g. Precision Aerospace LLC

Supply Chain Role*
Select your role... ▾

Target CMMC Level*
CMMC Level 2 (110 Controls · CU ▾

Current SPRS Score (Optional)
e.g. -35, +60, or 'Never Calculated'

How can our Registered Practitioners help you?*
Tell us about your upcoming contract renewals, DoD deadlines, or primary challenges with NIST SP 800-171.

Submit Discovery Call Request →

🔒 All communications are held under strict confidentiality. We do not sell or share contractor data.

// FREQUENTLY ASKED QUESTIONS

Frequently Asked Questions About Discovery Calls

Still have questions regarding your specific CMMC clauses or audit dates? Speak directly with our lead Registered Practitioner.

Book a Discovery Call →

Will you sign our bilateral Non-Disclosure Agreement (NDA) before we discuss contracts? ×

Yes, absolutely. We sign your company's bilateral NDA or provide our standard defense-grade mutual NDA within 2 business hours before any discovery call or review of contract clauses.

Can an RPO officially certify our company for CMMC Level 2? +

What information should I have ready for our 30-minute discovery call? +

How quickly can Secure-Centric begin an on-site scoping assessment? +